Sicherheitsnachweis-Toolkit · Handbuch

Warum jede Frage gestellt wird, welche Quelle dahintersteht und was ein kleiner Betrieb ehrlich vorweisen kann

Quellen am 19. Oktober 2026 am Original gelesen

0 So benutzen Sie das Toolkit

Das Toolkit macht aus vierzig Antworten sieben datierte Dokumente. Dieses Handbuch erklärt, warum jede Frage gestellt wird, welche Quelle dahintersteht, welche Antwort ein Fragebogen, ein Versicherer oder eine Vertragsklausel tatsächlich will, und was ein Betrieb ohne IT-Abteilung ehrlich vorweisen kann. Sie müssen es nicht lesen, bevor Sie anfangen. Jede Frage im Generator nennt den Abschnitt, der sie erklärt.

Die sieben Dokumente. D1 die Selbstauskunft Informationssicherheit: neun Abschnitte A bis I, eine Übersichtstabelle, jedes Feld mit Stand und Datum, von der Leitung unterschrieben; sie liegt jedem Fragebogen bei. D2 der Maßnahmenplan: jedes „teilweise“ und „noch nicht“ wird eine Maßnahme mit Priorität, Verantwortlichen, Termin in einer von drei Wellen und dem Nachweis, der danach vorliegt; als Tabelle mit Blatt Wiedervorlage. D3 die Notfallkarte: eine Seite für die Wand und die Lade. D4 die Nachweisliste: je Frage der Beleg, den Kunde oder Versicherer annehmen, ob er vorliegt, wo er liegt, seine Anlagennummer. D5 das Antwortschreiben mit Fragebogen-Abgleich: der Brief, der die Lücken mit Terminen nennt, und die Tabelle, die die typischen Fragen eines Fragebogens und die zehn Bereiche des Art. 21 Abs. 2 der NIS-2-Richtlinie den Abschnitten der Selbstauskunft zuordnet. D6 die Klausel-Prüfliste: die Sicherheitsklauseln, die Kunden in Verträge schreiben, was jede bedeutet, was ein kleiner Betrieb zusagen kann und was er verhandeln sollte. D7 die Nachweisseite: eine datierte Seite mit Dokumentnummer.

Die vier Antworten. Jede Statusfrage hat vier Antworten: vorhanden, teilweise, noch nicht mit Termin, nicht anwendbar mit Grund. „Noch nicht, bis Ende des Quartals“ ist eine vollständige Antwort. Ein Fragebogen, der sie bekommt, erfährt mehr als aus einem „Ja“, das bei der ersten Nachfrage zerfällt, und das Gesetz, das Ihren Kunden erfasst, verlangt genau das vom Kunden selbst: Wer eine Lücke feststellt, ergreift unverzüglich Korrekturmaßnahmen (Abschnitt 1.7). Das Toolkit schreibt nie „alle Anforderungen erfüllt“, „sicher“ oder eine Frist, die Sie nicht halten können.

Was das Toolkit nicht ist. Es ist keine Rechtsberatung, kein Audit und kein Zertifikat. Kein Dokument behauptet, dass der Betrieb ein Gesetz oder eine Norm erfüllt. Die Dokumente zeigen, was der Betrieb an einem Datum vorweisen kann, was er bis wann tun wird und wer dafür einsteht. Wo eine Quelle fehlt, sagt das Handbuch das und lässt die Entscheidung beim Betrieb.

Die vier Marker. Jede Aussage, auf die es ankommt, trägt einen von vier Markern. Fakt: Wortlaut oder Datum am Original gelesen; die Quelle steht mit Abrufdatum daneben. Auslegung: eine Schlussfolgerung, die Scutoria aus den Quellen zieht; man kann ihr widersprechen. Unsicher: die Quellen widersprechen sich oder die Rechtslage ist offen; das Handbuch sagt, was wann geprüft wurde. Lücke: keine Quelle beantwortet die Frage; der Betrieb entscheidet, und das Dokument lässt das Feld absichtlich offen.

Der Beispielbetrieb. Der Generator ist mit einem erfundenen Elektrotechnikbetrieb vorbelegt, zehn bis neunundvierzig Beschäftigte, Österreich, die IT teils von einem externen Dienstleister, teils vom Büro betreut. Ein Kunde hat einen Fragebogen geschickt. Die Beispielantworten zeigen ein realistisches Mischbild: Multi-Faktor-Authentifizierung bei E-Mail ja, bei der Cloud-Konsole noch nicht; tägliche Sicherung, aber keine Kopie außer Reichweite; nie geprobte Wiederherstellung; kein Notfallplan; ein alter Werkstattrechner. Keine Person und kein Betrieb in diesem Handbuch ist echt.

Die Reihenfolge der Arbeit. Die Fragen beantworten; rund vierzig Minuten. D1 und den Maßnahmenplan lesen. Die Notfallkarte drucken und die Nummern prüfen. Die Nachweise, die es schon gibt, in einer Stunde zusammenstellen (Abschnitt 3). Die Selbstauskunft mit dem Antwortschreiben senden oder für den Versicherer ablegen. Die erste Welle des Plans abarbeiten. Am Datum in D7 überprüfen.

1 Warum Sie gefragt werden

Vier Arten von Anfragen erreichen kleine Betriebe: ein Fragebogen eines größeren Kunden, ein Vertrag mit Sicherheitsklauseln, der Antrag eines Cyberversicherers und der Wunsch, ein Gütesiegel oder Zertifikat vorzulegen. Dieser Abschnitt sagt, woher jede kommt und warum die Größe des Betriebs den Maßstab setzt.

1.1 Kunden unter der NIS-2-Richtlinie

FAKT

Die NIS-2-Richtlinie gilt für öffentliche oder private Einrichtungen der in ihren Anhängen I und II genannten Art, die nach der KMU-Empfehlung der Kommission als mittlere Unternehmen gelten oder deren Schwellenwerte überschreiten, mit größenunabhängigen Ausnahmen in Art. 2 Abs. 2. Mittel heißt: fünfzig Beschäftigte oder mehr, oder Umsatz und Bilanzsumme beide über zehn Millionen Euro, bis 249 Beschäftigte und fünfzig beziehungsweise dreiundvierzig Millionen Euro. Zu den Sektoren gehören Energie, Verkehr, Banken, Gesundheit, Wasser, digitale Infrastruktur, öffentliche Verwaltung, Raumfahrt, Post, Abfall, Chemie, Lebensmittel, die Herstellung von Medizinprodukten, Computern, elektrischen Ausrüstungen, Maschinen und Fahrzeugen, digitale Anbieter und Forschung.

→ Quelle: Richtlinie (EU) 2022/2555, Art. 2 Abs. 1 und 2, Anhänge I und II · EUR-Lex · abgerufen 19.10.2026; Empfehlung 2003/361/EG der Kommission, Anhang, Art. 2 · abgerufen 19.10.2026

FAKT

Solche Einrichtungen müssen „geeignete und verhältnismäßige technische, operative und organisatorische Maßnahmen“ ergreifen. Die Maßnahmen umfassen zumindest zehn Bereiche, darunter „Sicherheit der Lieferkette einschließlich sicherheitsbezogener Aspekte der Beziehungen zwischen den einzelnen Einrichtungen und ihren unmittelbaren Anbietern oder Diensteanbietern“. Bei der Erwägung geeigneter Lieferkettenmaßnahmen berücksichtigen sie „die spezifischen Schwachstellen der einzelnen unmittelbaren Anbieter und Diensteanbieter sowie die Gesamtqualität der Produkte und der Cybersicherheitspraxis ihrer Anbieter und Diensteanbieter, einschließlich der Sicherheit ihrer Entwicklungsprozesse“.

→ Quelle: Richtlinie (EU) 2022/2555, Art. 21 Abs. 1, Abs. 2 Buchst. d und Abs. 3 · EUR-Lex, deutsche Fassung · abgerufen 19.10.2026

AUSLEGUNG

Das ist der Fragebogen. Die Richtlinie sagt dem Kunden nicht, was er einen Lieferanten fragen soll; sie verpflichtet ihn, dessen Praxis zu berücksichtigen, und ein Fragebogen ist der billigste Weg, das für hunderte Lieferanten auf einmal zu tun. Die Fragen folgen deshalb den zehn Bereichen des Kunden, und die Selbstauskunft folgt den Fragen. Die Richtlinie bindet den Kunden, nicht Sie; Sie bindet der Vertrag, der folgt (Abschnitt 1.2 und D6).

FAKT

Die Richtlinie wird durch nationales Recht umgesetzt. In Deutschland ist das geänderte BSI-Gesetz seit 6. Dezember 2025 in Kraft. In Österreich gilt das Netz- und Informationssystemsicherheitsgesetz 2026 (NISG 2026) in seinen Kernteilen seit 1. Oktober 2026; sein § 32 Abs. 4 wiederholt die zehn Bereiche, mit „Sicherheit der Lieferkette einschließlich sicherheitsbezogener Aspekte der Beziehungen zwischen den einzelnen Einrichtungen und ihren unmittelbaren Anbietern oder Diensteanbietern“ in Buchstabe d, und § 33 Abs. 1 verpflichtet wesentliche und wichtige Einrichtungen, der Behörde binnen zwölf Monaten nach Eintritt der Registrierungspflicht eine strukturierte Selbstdeklaration zu übermitteln, „insbesondere betreffend die genutzten Netz- und Informationssysteme und die Sicherheit der Lieferketten“.

→ Quelle: BSI-Gesetz in der Fassung des deutschen NIS-2-Umsetzungsgesetzes, in Kraft seit 6.12.2025 · gesetze-im-internet.de · abgerufen 19.10.2026; NISG 2026, BGBl. I Nr. 94/2025 vom 23.12.2025, § 32 Abs. 4, § 33 Abs. 1 · ris.bka.gv.at · abgerufen 19.10.2026

AUSLEGUNG

Für einen österreichischen Kunden ist der Lieferantenfragebogen das Rohmaterial seiner eigenen Selbstdeklaration. Wer Sie 2026 fragt, sammelt, was er 2027 an die Behörde schicken muss. Das erklärt Ton und Fristen der Anfragen; es macht Ihre Antworten nicht zu einer Eingabe bei der Behörde. Die Selbstauskunft beschreibt Ihren Betrieb; was der Kunde damit tut, entscheidet er.

1.2 Die Durchführungsverordnung: der Vertrag hinter dem Fragebogen

FAKT

Für digitale Anbieter (DNS, Cloud, Rechenzentren, verwaltete Dienste, Online-Marktplätze, Suchmaschinen, soziale Netzwerke, Vertrauensdienste) hat die Kommission die technischen Anforderungen der zehn Bereiche in der Durchführungsverordnung (EU) 2024/2690 festgelegt, veröffentlicht im Amtsblatt am 18. Oktober 2024, in Kraft seit 7. November 2024. Ihr Anhang Nr. 5.1.4 sagt, was solche Einrichtungen „soweit angemessen" in ihre Verträge mit Anbietern schreiben: Cybersicherheitsanforderungen; Sensibilisierungs-, Qualifikations- und Ausbildungsanforderungen sowie soweit angemessen Zertifizierungen der Mitarbeitenden des Anbieters; Zuverlässigkeitsüberprüfungen der Mitarbeitenden; eine Verpflichtung, Sicherheitsvorfälle „unverzüglich zu melden"; das Recht auf Prüfung oder auf Prüfberichte; eine Verpflichtung zur Behebung von Schwachstellen; Anforderungen an die Unterauftragsvergabe; und Pflichten bei Vertragskündigung, „z. B. Abruf und Entsorgung der Informationen". Nr. 5.2 verlangt ein Verzeichnis der direkten Anbieter mit Kontaktstellen und der Liste der gelieferten Produkte und Dienste.

→ Quelle: Durchführungsverordnung (EU) 2024/2690 der Kommission vom 17.10.2024, ABl. L, 2024/2690, 18.10.2024, Art. 2 Abs. 1, Art. 16, Anhang Nr. 5.1.4 und 5.2 · EUR-Lex, deutsche und englische Fassung · abgerufen 19.10.2026

FAKT

In Österreich gilt derselbe Anhang für jede wesentliche und wichtige Einrichtung: Die Verordnung der Cybersicherheitsbehörde vom 1. Oktober 2026 (NISV 2026) erklärt die Anforderungen gemäß Art. 2 samt Anhang der Durchführungsverordnung „auch auf die nicht von dieser Durchführungsverordnung umfassten in den Anlagen 1 und 2 des Netz- und Informationssystemsicherheitsgesetzes 2026 … gelisteten Arten wesentlicher und wichtiger Einrichtungen anwendbar".

→ Quelle: NISV 2026, BGBl. II Nr. 290/2026 vom 1.10.2026, § 2 · ris.bka.gv.at · abgerufen 19.10.2026

AUSLEGUNG

Die acht Vertragsinhalte der Nr. 5.1.4 sind damit das Muster der Klauseln, die Sie sehen werden: von digitalen Anbietern in der ganzen Union und von jedem NIS-2-Kunden in Österreich. Ein deutscher Kunde außerhalb der digitalen Sektoren ist an den Anhang nicht von Gesetzes wegen gebunden, aber seine Prüfer und Juristen lesen denselben Text. D6 nimmt die acht Inhalte einzeln und sagt, was ein kleiner Betrieb zusagen kann.

1.3 Finanzkunden: DORA

FAKT

Banken, Versicherer, Wertpapierfirmen und andere Finanzunternehmen fallen unter die Verordnung über die digitale operationale Resilienz. Ihr Art. 30 Abs. 2 nennt neun Inhalte, die jeder Vertrag über IKT-Dienstleistungen enthalten muss, darunter die Leistungsbeschreibung einschließlich Unterauftragsvergabe, die Orte der Datenverarbeitung und die Vorabinformation bei deren Änderung, Datenschutzvorgaben, Zugang und Rückgabe der Daten, Dienstleistungsgüte, Unterstützung bei Vorfällen, Zusammenarbeit mit Behörden und Kündigungsrechte. Art. 30 Abs. 3 fügt sechs für kritische oder wichtige Funktionen hinzu, darunter vollständige Leistungsgüte, Kündigungs- und Berichtspflichten, Notfallpläne und Sicherheitsmaßnahmen, Teilnahme an bedrohungsorientierten Penetrationstests, uneingeschränkte Zugangs- und Prüfrechte und Ausstiegsstrategien.

→ Quelle: Verordnung (EU) 2022/2554 (DORA), Art. 28 Abs. 8, Art. 30 Abs. 2 und 3 · EUR-Lex, englische Fassung · abgerufen 19.10.2026

AUSLEGUNG

Ein kleiner Lieferant eines Versicherers oder einer Bank begegnet dem als fertigem Klauselsatz, den er unterschreiben soll. Teil B von D6 erklärt jede Klausel; die ehrliche Antwort auf die meisten ist „ja, in diesen Grenzen“, und das Prüfrecht ist die Klausel zum Verhandeln: uneingeschränkter Zugang ist für Cloud-Anbieter geschrieben, nicht für einen Elektriker mit einem Server.

1.4 Versicherer

FAKT

Sechs öffentliche Antragsformulare und Bedingungen von Cyberversicherern wurden ganz gelesen. Was alle fragen: tägliche Sicherung auf getrennte Systeme mit geprüfter Wiederherstellung (Mannheimer 4.1, 4.2, 4.5, 4.6, 4.9; Markel Abschnitt 4 Nr. 5 und 7.2; Beazley kritische Anforderung 1; Funk 1); Multi-Faktor-Authentifizierung für Cloud-Dienste, E-Mail, Fernzugriff und Administratoren (Mannheimer 7.7.1, 7.7.3, 8.1; Markel 6.2; Allianz 2.5.5; Beazley 2 und 3); Patches zeitnah und keine Software ohne Hersteller-Updates (Mannheimer 7.1; Markel 7.3 „innerhalb von vier Wochen", ab CVSS 8,0 „unverzüglich"; Allianz 2.5.1 und 2.5.3; Beazley und Funk 5); Schutzsoftware auf allen Geräten mit automatischen Updates (Mannheimer 7.2; Markel 7.3; Beazley; Funk 7); jährliche Schulung mit Anti-Phishing (Mannheimer 5.4; Markel 6.4; Beazley 4; Funk 4); ein Verantwortlicher und ein schriftliches Notfall- und Wiederanlaufkonzept (Mannheimer 5.1, 5.10; Markel 6.3); Administratorrechte nur für die Administration (Mannheimer 6.3, 6.5; Allianz 2.5.4); ein Prozess für Vergabe und Entzug von Zugriffsrechten (Mannheimer 5.5); Netzsegmentierung (Mannheimer 7.4). Beazley nennt vier davon „zwingende Voraussetzung für den Abschluß einer Cyber-Deckung". Die Bedingungen eines österreichischen Versicherers verpflichten den Versicherungsnehmer zu angemessenen Schutzmaßnahmen „insbesondere bei Computer-Backups, Anti-Viren- und Anti-Malware-Software, Kennworteinstellungen, Berechtigungskonzepten, Systemkonfigurationen, Firewalls sowie bei der Aktualisierung von Software", zur Meldung an den Versicherer „spätestens innerhalb einer Woche ab Kenntnis", und versichern private Geräte nur, soweit ihr Zugriff einer Zwei-Faktor-Authentifizierung unterliegt.

→ Quelle: Mannheimer Versicherung AG, Fragebogen Cyber-Risiken, HF_060 0424; Markel Insurance SE, Fragebogen Pro Cyber v2; Allianz Versicherungs-AG, Fragebogen für Unternehmen der Informationstechnologie, 9.25; Beazley, Sicherheitsanforderungen für die Cyber Versicherung; Funk International Austria mit Beazley, Antrag und Risikofragebogen, Juli 2022; Donau Versicherung AG, Allgemeine Bedingungen für die Cyberversicherung, Fassung 2025, Teil D 7.1.3 und 7.1.4, Teil E · abgerufen 19.10.2026

AUSLEGUNG

Die Versicherer fragen dieselben sieben Dinge, die das Gesetz die Kunden fragen lässt, in einfacheren Worten und mit Zahlen. Wo das Toolkit einen Rhythmus nennt (täglich, jährlich, innerhalb von Tagen), nimmt es den strengsten der Formulare, weil die Selbstauskunft vor allen bestehen muss. Wo ein Formular strenger ist als das Gesetz, sagt das Handbuch das bei der Frage.

1.5 Gütesiegel, Checks und Zertifikate

FAKT

Österreich hat ein Gütesiegel mit vier Stufen. Das Cyber Trust Austria Label gibt die CTS Cyber Trust Services GmbH aus; das zugrunde liegende Rating gehört dem KSV1870, das Schema dem Kompetenzzentrum Sicheres Österreich. Die Stufe Standard beruht auf einer Selbstdeklaration zu vierzehn veröffentlichten Fragen (B1 bis B14), vom KSV1870 validiert; Silber und Gold ergänzen elf Fragen (A1 bis A11), Gold mit Audit durch eine qualifizierte Stelle; Platinum beruht auf den fünfzig Anforderungen der Durchführungsverordnung. Das Label gilt ein Jahr. Seine Schema Policy, Version 6.0 vom 8. September 2025, veröffentlicht die Fragen; die Website nennt als Zielgruppe Lieferanten wesentlicher und wichtiger Einrichtungen nach dem NISG 2026.

→ Quelle: Cyber Trust Austria, Cyber Risk Rating & Cyber Trust Label Schema Policy 2026, Version 6.0 vom 8.9.2025, S. 5 bis 21; cyber-trust.at, Labelübersicht und Fragenliste B · abgerufen 19.10.2026

FAKT

Deutschland hat einen Check, kein Zertifikat. Der CyberRisikoCheck nach DIN SPEC 27076:2023-05 ist ein ein- bis zweistündiges Interview durch einen qualifizierten IT-Dienstleister zu 27 Anforderungen aus sechs Themenbereichen, gedacht für Betriebe bis fünfzig Beschäftigte; das BSI nennt ihn „keine IT-Sicherheitszertifizierung“, NIS-2-Konformität lässt sich damit nicht erreichen; die DIN SPEC ist nach Anmeldung kostenfrei. Das BSI hat am 6. Juni 2025 den tausendsten Dienstleister qualifiziert und berichtet, dass die Betriebe im Schnitt nur knapp 56 Prozent der Anforderungen erfüllten. VdS 10000:2025-01 ist ein Managementstandard für KMU der Prüfstelle der Versicherer, aufgebaut auf ISO 27001 und dem BSI-Grundschutz, mit drei Jahre gültigem Zertifikat und reduzierten jährlichen Re-Audits; Versichererformulare nennen ihn neben ISO 27001.

→ Quelle: BSI, Seite CyberRisikoCheck und Pressemitteilung vom 6.6.2025; BSI, Die Lage der IT-Sicherheit in Deutschland, Abschnitt KMU; DIN Media, DIN SPEC 27076; VdS 10000 : 2025-01 (03), Inhalt und Vorbemerkungen; VdS 5569 : 2018-10, S. 5 und 9 · abgerufen 19.10.2026

FAKT

ISO/IEC 27001:2022 ist die internationale Norm; ihr Anhang A listet 93 Maßnahmen in vier Themen, übernommen aus ISO/IEC 27002:2022. Die Norm ist kostenpflichtig (CHF 155). TISAX ist das Prüfschema der Automobilindustrie auf dem Katalog VDA ISA, betrieben von ENX, mit drei Prüfstufen und drei Jahren Gültigkeit. Der SIG von Shared Assessments ist eine Fragenbibliothek im Abonnement mit 21 Risikodomänen.

→ Quelle: committee.iso.org und IEC Webstore, ISO/IEC 27001:2022, Ausgabe 3; SC 27 Journal 2025, Heft 1, S. 10, 18 bis 19; ENX Association, TISAX-Handbuch und „NIS2 fulfilment through TISAX“, 24.4.2025; Shared Assessments, SIG · abgerufen 19.10.2026

◆ AUSLEGUNG

Für einen Betrieb mit zehn bis fünfzig Beschäftigten ist keines davon der erste Schritt, und die meisten Kunden verlangen keines. Wir haben nach einem Kunden oder einer Ausschreibung gesucht, die das österreichische Label verlangt, und keine gefunden; nur Pressemeldungen von Label-Inhabern. Die Reihenfolge, die funktioniert: zuerst die Selbstauskunft mit Nachweisen (dieses Toolkit), dann, wenn ein Kunde oder Versicherer eine externe Prüfung will, die billigste passende: in Deutschland der CyberRisikoCheck, in Österreich das Label Standard; beide fragen die Fragen der Blöcke B bis H in eigenen Worten. Frage B3 hält fest, was Sie schon haben; D4 führt ein Zertifikat als Anlage, mehr nicht.

1.6 Warum die Größe den Maßstab setzt

■ FAKT

Die Richtlinie selbst bindet die Maßnahmen an die Größe: „Bei der Bewertung der Verhältnismäßigkeit dieser Maßnahmen sind das Ausmaß der Risikoexposition der Einrichtung, die Größe der Einrichtung und die Wahrscheinlichkeit des Eintretens von Sicherheitsvorfällen und deren Schwere … gebührend zu berücksichtigen.“ Die Durchführungsverordnung wiederholt das für ihren Anhang und fügt hinzu, dass eine Einrichtung, die eine Anforderung für nicht angemessen, nicht anwendbar oder nicht durchführbar hält, die Gründe dokumentiert; ihr Erwägungsgrund 5 sagt, dass Kleinstunternehmen, die Pflichten nicht trennen können, „Ausgleichsmaßnahmen wie eine gezielte Beaufsichtigung durch ihr Management oder eine verstärkte Überwachung und Protokollierung“ in Betracht ziehen können. Das österreichische Gesetz wiederholt den Maßstab in § 32 Abs. 3 NISG 2026, und seine Verordnung verpflichtet Einrichtungen, kompensierende Maßnahmen zu dokumentieren und jährlich zu überprüfen.

→ Quelle: Richtlinie (EU) 2022/2555, Art. 21 Abs. 1 Unterabs. 2; Durchführungsverordnung (EU) 2024/2690, Art. 2 Abs. 2 und Erwägungsgrund 5; NISG 2026, § 32 Abs. 3; NISV 2026, § 4 · abgerufen 19.10.2026

◆ AUSLEGUNG

Die Verhältnismäßigkeit ist für die Einrichtung geschrieben, nicht für ihre Lieferanten, aber ein Kunde, der dokumentieren muss, warum eine Maßnahme für ihn angemessen ist, kann von einem Zehn-Personen-Lieferanten nicht mehr verlangen als von sich. Deshalb beginnt die Selbstauskunft mit der Größe des Betriebs (Frage A3), und deshalb sagt D5 im ersten Absatz, dass die Antworten die eines kleinen Betriebs sind. Nichts im Toolkit verlangt von einem kleinen Betrieb ein Security Operations Center, Penetrationstests oder eine Zertifizierung; das sind die Silber- und Gold-Fragen des Labels, nicht die Standard-Fragen.

1.7 Warum „noch nicht, mit Termin“ eine vollständige Antwort ist

FAKT

Die Richtlinie verpflichtet eine Einrichtung, die feststellt, dass sie den Maßnahmen nicht nachkommt, „unverzüglich alle erforderlichen, angemessenen und verhältnismäßigen Korrekturmaßnahmen“ zu ergreifen. Die Durchführungsverordnung verlangt die Überwachung der Einhaltung und regelmäßige Berichte an die Leitungsorgane; Österreichs § 33 Abs. 3 erwartet einen Prüfbericht „einschließlich festgestellter Mängel und einen Maßnahmenplan zur Beseitigung der Mängel“.

→ Quelle: Richtlinie (EU) 2022/2555, Art. 21 Abs. 4; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 2.2.1; NISG 2026, § 33 Abs. 3 · abgerufen 19.10.2026

AUSLEGUNG

Das Gesetz kennt die Lücke mit Plan als Normalzustand; es bestraft die versteckte Lücke, nicht die dokumentierte. Ein Lieferant, der schreibt „noch nicht, geplant bis 31. März, verantwortlich: die Büroleitung mit dem IT-Dienstleister“, gibt dem Kunden, was der Kunde für sich selbst erzeugen muss. Das ist die ganze Begründung der vier Antworten und des Maßnahmenplans, und deshalb führt D7 offene Punkte auf, statt sie zu verstecken.

2 Die Bereiche der Selbstauskunft

Jeder Bereich ist ein Block des Fragebogens und ein Abschnitt von D1. Zu jeder Frage sagt das Handbuch, was gefragt wird, welche Quelle danach fragt, was ein kleiner Betrieb realistisch vorweisen kann und was der Beispielbetrieb geantwortet hat. Die Notfallfragen des Blocks F erklärt auch Abschnitt 4. Zitate aus englischen Quellen sind unsere Übersetzung.

2.1 B · Organisation

B1 Schriftliche Sicherheitsregeln. Ein bis zwei Seiten für die Belegschaft: Geräte, Passwörter, E-Mail, Zahlungen, was gemeldet wird und an wen.

FAKT

Die erste Frage des österreichischen Labels lautet: „Haben Sie eine aktuelle Informationssicherheitsrichtlinie (bzw. IT-Sicherheitsrichtlinie), die für ihr Unternehmen gültig ist?“ Der erste der zwölf ENISA-Schritte für KMU ist der Aufbau einer Sicherheitskultur, mit „Sicherheitsrichtlinien veröffentlichen“ als Teilschritt. Die Durchführungsverordnung eröffnet ihren Anhang mit dem Konzept für die Sicherheit von Netz- und Informationssystemen; VdS 10000 widmet der Leitlinie und den Richtlinien die Kapitel 5 und 6; Mannheimer fragt nach einem Verantwortlichen.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, B1; ENISA, Cybersecurity guide for SMEs, 12 steps, 28.6.2021, Schritt 1; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 1.1; VdS 10000:2025-01, Kapitel 5 und 6; Mannheimer, 5.1 · abgerufen 19.10.2026

◆ AUSLEGUNG

Zwei Seiten, von der Leitung unterschrieben und von jeder Person bestätigt, genügen jedem Fragebogen, den wir gelesen haben; niemand verlangt von einem Zehn-Personen-Betrieb ein Managementsystem. Der Beispielbetrieb hat Regeln für Passwörter und E-Mail, aber nicht für Zahlungen und Meldungen: „teilweise“, die Regeln werden in der ersten Welle ergänzt.

B2 Cyberversicherung. Ob eine Police besteht, mit Versicherer, Notfallnummer und Meldefrist.

◆ AUSLEGUNG

Kein Gesetz verlangt eine Cyberversicherung, und kein gelesener Fragebogen fragt sie als Bedingung ab; die Frage steht, weil die Formulare der Versicherer selbst, die Frage A9 des Labels (qualifizierte Ressourcen im Ernstfall, auch „über eine Cyberversicherung“) und die Notfallkarte die Antwort brauchen: Die Notfallnummer der Police und ihre Meldefrist gehören auf die Karte. D1 berichtet den Umstand ohne Wertung. Der Beispielbetrieb hat keine Police.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, A9; Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4 · abgerufen 19.10.2026

B3 Zertifikate, Gütesiegel, Prüfungen. Was der Betrieb schon hat: ISO 27001, das österreichische Label, TISAX, einen CyberRisikoCheck, anderes.

■ FAKT

Versicherer fragen danach: Allianz 1.2 nennt ISO 27001 und VdS 10000; Mannheimer 5.3 fragt, ob der Betrieb regelmäßig Analysen nach ISO 27001, IT-Grundschutz oder DIN SPEC 27076 durchführt, und 9.2, ob der IT-Dienstleister zertifiziert ist. Die Durchführungsverordnung verlangt von den erfassten Einrichtungen eine unabhängige Überprüfung ihrer Sicherheit und Konzepte zur Bewertung der Wirksamkeit.

→ Quelle: Allianz, 1.2; Mannheimer, 5.3 und 9.2; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 2.3 und 7 · abgerufen 19.10.2026

◆ AUSLEGUNG

Was es gibt, wird eine Anlage in D4; was es nicht gibt, ist keine Lücke im Plan, denn Abschnitt 1.5 erklärt, warum ein Zertifikat nicht der erste Schritt ist. Der Beispielbetrieb hat keines.

2.2 C · Zugang und Identität

C1 Ein Konto je Person.

■ FAKT

Markels Formular fragt, ob „für jeden Nutzer und Administrator eine benutzerindividuelle Kennung/Zugang mit Passwort vergeben“ ist. Die Durchführungsverordnung verlangt die Identifizierung der Nutzer und die Authentifizierung; der BSI-Grundschutzbaustein zum Identitäts- und Berechtigungsmanagement verlangt individuelle Konten; die TISAX-Kontrollfrage 4.1.3 fragt, wie Nutzerkonten und Anmeldedaten verwaltet werden.

→ Quelle: Markel, 6.2; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 11.5 und 11.6; BSI, IT-Grundschutz ORP.4, Edition 2023; ENX, NIS2 fulfilment through TISAX, Kontrollfrage 4.1.3 · abgerufen 19.10.2026

◆ AUSLEGUNG

Geteilte Logins brechen jede andere Maßnahme: Man kann nicht entziehen, nicht protokollieren, nicht zuordnen. Wo ein Tool nur ein Login erlaubt, legt die Maßnahme in D2 dessen Passwort mit benannter verantwortlicher Person in den Passwort-Manager. Der Beispielbetrieb hat „vorhanden" geantwortet.

C2 Multi-Faktor-Authentifizierung für jedes E-Mail-Konto.

■ FAKT

Die Versicherer stellen sie an den Anfang: Beazleys kritische Anforderung 2 und Funks Frage 2 verlangen Multi-Faktor-Authentifizierung „für Cloud-basierte Dienste (z.B. für den Zugriff auf Cloud-basierte E-Mail-Konten) und für alle Fernzugriffe". Die Frage B6 des österreichischen Labels fragt nach angemessenen Authentifizierungsmaßnahmen mit dem Kriterium „Zumindest bei kritischen Systemen muss MFA (Multi-Faktor Authentisierung) in Verwendung sein." Die Durchführungsverordnung verlangt, dass Nutzer „soweit angemessen – durch mehrere Authentifizierungsfaktoren oder kontinuierliche Authentifizierungsmechanismen" authentifiziert werden, im Einklang mit der Klassifizierung des Werts; die Richtlinie nennt Multi-Faktor-Authentifizierung in Art. 21 Abs. 2 Buchst. j. ENISA-Schritt 5 ist „Zugang zu Systemen sichern" mit „Multi-Faktor-Authentifizierung einschalten"; das österreichische Bundeskriminalamt nennt MFA für E-Mail-Konten als erste technische Maßnahme gegen CEO Fraud.

→ Quelle: Beazley, Anforderung 2; Funk, Frage 2; Cyber Trust Austria, Schema Policy 2026, B6; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 11.7.1; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. j; ENISA, 12 steps, Schritt 5; Bundeskriminalamt, CEO Fraud, Stand 29.6.2026 · abgerufen 19.10.2026

■ FAKT

Zum Verfahren: Der US-Standard für digitale Identitäten behandelt Phishing-Resistenz als Eigenschaft des Authentifizierungsmittels, und die CISA stuft Authenticator-Apps und Sicherheitsschlüssel über Codes per SMS, die sie unter den MFA-Verfahren zuletzt reiht, aber noch über ein Passwort allein.

→ Quelle: NIST SP 800-63B-4, Juli 2025; CISA, Implementing Phishing-Resistant MFA, Oktober 2022 · abgerufen 19.10.2026

◆ AUSLEGUNG

Dass jedes Postfach „kritisch" ist, ist unser Schluss, nicht der Wortlaut des Labels: Der ENISA-Bericht für KMU beschreibt das gekaperte Postfach als Beginn des Zahlungsbetrugs, und das Erste, was ein Angreifer mit einem Postfach tut, ist die Passwörter alles anderen zurückzusetzen. Der Beispielbetrieb hat auf jedem Postfach eine Authenticator-App: „vorhanden".

C3 Multi-Faktor-Authentifizierung für Fernzugriff, Administratoren, Cloud-Konsolen und Online-Banking.

FAKT

Mannheimer fragt, ob MFA für den Zugriff auf wichtige Systeme eingesetzt wird, ob Administratoren „zwingend MFA" für die internen Server-Systeme und Cloud-Strukturen benötigen und ob der Zugriff aus dem Homeoffice ausschließlich mit Mehrfachauthentifizierung erfolgt. Markel verlangt MFA für Fernzugriffe auf alle Systeme und für Administratoren und erlaubt bei größeren Betrieben Fernzugriff nur über Zwei-Faktor-Authentifizierung oder VPN. Allianz fragt, ob Anmeldungen von außerhalb des Unternehmensnetzwerks ausschließlich mit MFA möglich sind. Beazleys Anforderungen 2 und 3: MFA für alle Fernzugriffe, kein Fernzugriff ohne VPN. Die Frage A6 des Labels nennt MFA „für alle von extern erreichbaren Systemen wie zB. VPN, Jumphosts, Remote Support Tools, Webmail". Die Durchführungsverordnung verlangt „starke Verfahren zur Identifizierung, Authentifizierung (z. B. Multifaktor-Authentifizierung) und Genehmigung für privilegierte Konten und Systemverwaltungskonten" und Kontrollen für den Fernzugriff „einschließlich des Zugangs von Diensteanbietern". Der österreichische Versicherer versichert private Geräte nur, soweit ihr Zugriff einer Zwei-Faktor-Authentifizierung unterliegt.

→ Quelle: Mannheimer, 7.7.1, 7.7.3, 8.1; Markel, Abschnitt 4 Nr. 6 und 6.2; Allianz, 2.5.5; Beazley, 2 und 3; Cyber Trust Austria, Schema Policy 2026, A6; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 11.3.2 Buchst. a und 6.7.2 Buchst. d; Donau Versicherung, AVB Cyber 2025, Teil E · abgerufen 19.10.2026

AUSLEGUNG

Das Online-Banking steht auf der Liste, weil die Bank den zweiten Faktor ohnehin erzwingt und weil die Notfallkarte die Bank nennt; kein Fragebogen fragt danach. Der Beispielbetrieb: VPN ja, die Administrationskonsole der Cloud noch nicht: „teilweise", erste Welle.

C4 Konten Ausscheidender am selben Tag deaktiviert, anhand einer Liste aller Konten.

FAKT

Mannheimer fragt, ob „ein formaler Prozess für die Zuweisung und den Widerruf von Zugriffsrechten" existiert. Die Durchführungsverordnung verlangt Verfahren zur Beendigung oder Änderung des Beschäftigungsverhältnisses, die Verwaltung der Zugriffsrechte und die Rückgabe oder Löschung von Anlagen und Werten bei Beendigung; die Frage B4 des Labels verlangt ein gepflegtes Verzeichnis aller IT-Assets und -Services inklusive Cloud-Dienste; der ENISA-Bericht für KMU nennt den Entzug des Zugangs beim Austritt unter seinen Empfehlungen.

→ Quelle: Mannheimer, 5.5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 10.3, 11.2, 12.5; Cyber Trust Austria, Schema Policy 2026, B4; ENISA, Cybersecurity for SMEs, Juni 2021 · abgerufen 19.10.2026

◆ AUSLEGUNG

„Am selben Tag“ ist unsere Regel; die Quellen sagen „Verfahren“. Die Liste aller Konten je Person ist der Nachweis, der das Verfahren erst möglich macht, und dieselbe Liste, die C1 braucht. Der Beispielbetrieb hat keine schriftliche Liste: „teilweise“.

C5 Tägliche Arbeit ohne Administratorrechte, getrennte Konten für die Administration.

■ FAKT

Mannheimer fragt, ob administrative Zugänge „ausschließlich Administratoren und ausschließlich zur Erledigung administrativer Tätigkeiten vorbehalten“ sind und ob lokale Administratorrechte auf Client-Systemen deaktiviert wurden; Allianz fragt nach differenzierten Admin-Rechten; die Frage B5 des Labels verlangt ein Berechtigungskonzept, „das jedem nur die für seine Arbeit notwendigen Rechte einräumt“. Die Durchführungsverordnung verlangt spezielle Konten, „die ausschließlich für Systemverwaltungsvorgänge … zu verwenden sind“, und gesonderte Authentifizierung für privilegierte Konten oder Verwaltungskonten.

→ Quelle: Mannheimer, 6.3 und 6.5; Allianz, 2.5.4; Cyber Trust Austria, Schema Policy 2026, B5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 11.3.2 Buchst. b und 11.6.2 Buchst. f · abgerufen 19.10.2026

◆ AUSLEGUNG

Das ist die eine Maßnahme, die nichts kostet und die meiste Schadsoftware am Installieren hindert. Der Beispielbetrieb arbeitet auf jedem Rechner mit Administratorrechten: „noch nicht“, erste Welle, mit dem IT-Dienstleister.

C6 Passwortregel: ein langes Passwort je Konto in einem Passwort-Manager, nur bei Verdacht geändert.

■ FAKT

Der US-Standard verlangt mindestens fünfzehn Zeichen, wo das Passwort der einzige Faktor ist, und acht, wo ein zweiter Faktor dazukommt, verbietet Kompositionsregeln und den regelmäßigen Wechsel ohne Hinweis auf eine Kompromittierung, verlangt den Abgleich mit Sperrlisten bekannter Passwörter und erlaubt Passwort-Manager. Das BSI hat sich am 31. Januar 2025 und am 30. Januar 2026 öffentlich gegen erzwungene regelmäßige Wechsel ausgesprochen. Die Bedingungen des österreichischen Versicherers nennen „Kennworteinstellungen“ unter den Obliegenheiten des Versicherungsnehmers.

→ Quelle: NIST SP 800-63B-4, Juli 2025, Abschnitte 3.1.1.1 und 3.1.1.2; BSI-Pressemitteilungen vom 31.1.2025 und 30.1.2026; Donau Versicherung, AVB Cyber 2025, Teil D 7.1.3 · abgerufen 19.10.2026

◐ UNSICHER

Die Durchführungsverordnung weist in die andere Richtung: Sie verlangt von den erfassten Einrichtungen, „die Änderung von Authentifizierungsdaten zu Beginn, sodann in vorab festgelegten Zeitabständen und immer dann“ zu verlangen, „wenn der Verdacht besteht, dass die Authentifizierungsdaten beeinträchtigt wurden“, die Sperrung von Nutzern nach einer vorab festgelegten Zahl erfolgloser Anmeldeversuche und eine Stärke der Authentifizierung, die dem Wert angemessen ist.

→ Quelle: Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 11.6.2 Buchst. a, c und d, deutsche und englische Fassung · abgerufen 19.10.2026

◐ UNSICHER **Welche Passwortregel soll ein Lieferant zusagen?**

Die Standardisierungsstellen und die Durchführungsverordnung der Kommission widersprechen sich beim regelmäßigen Wechsel. Das Toolkit folgt NIST und BSI: lang, einmalig, im Manager, bei Verdacht geändert, durch einen zweiten Faktor geschützt. Besteht ein Kunde oder Versicherer auf Intervallen und beruft sich auf die Verordnung, ist die ehrliche Antwort, ein Intervall für Konten ohne zweiten Faktor zu vereinbaren und MFA überall sonst zu behalten; D1 sagt, welche Regel gilt. Eine Gerichts- oder Behördenentscheidung zu diesem Widerspruch wurde nicht gesucht.

ZULETZT GEPRÜFT 19.10.2026 · OFFENER PUNKT 6.17

◆ AUSLEGUNG

Der Beispielbetrieb hat einen Manager fürs Büro, aber nicht für den Außendienst: „teilweise“.

2.3 D · Sicherung und Betrieb

D1 Tägliche automatische Sicherung aller Geschäftsdaten mit einer Kopie offline oder sonst außerhalb der Reichweite eines Angreifers.

FAKT

Jedes Versichererformular fragt danach: wie oft, ob die Speichermedien von den aktiven Systemen physisch getrennt sind, ob eine Änderung oder Vernichtung der Sicherung ausgeschlossen ist, ob das Backup-System im selben Verzeichnisdienst hängt, ob ein Sicherungs- und Wiederherstellungskonzept besteht (Mannheimer 4.1, 4.5, 4.6, 4.7, 4.9); Markel verlangt Sicherungen „auf separierten Systemen oder Datenträgern“, unter einer Million Euro Umsatz mindestens wöchentlich, darüber täglich; Beazleys erste kritische Anforderung sind getestete Offline-Backups; Funks Frage 1 verlangt einen „kalten“ oder Offline-Speicherort, „der von einem Problem mit Ihrer Live-Umgebung nicht betroffen wäre“. Die Durchführungsverordnung verlangt die „Speicherung von Sicherungskopien (online oder offline) an einem oder mehreren sicheren Orten, die sich nicht im selben Netz wie das System sowie in ausreichend großer Entfernung befinden“. ENISA-Schritt 9 ist „Sicherungen schützen“; Bereich c der Richtlinie nennt „Backup-Management und Wiederherstellung nach einem Notfall“.

→ Quelle: Mannheimer, 4.1, 4.5, 4.6, 4.7, 4.9; Markel, Abschnitt 4 Nr. 5; Beazley, 1; Funk, 1; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 4.2.2 Buchst. c; ENISA, 12 steps, Schritt 9; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. c · abgerufen 19.10.2026

AUSLEGUNG

„Außer Reichweite“ ist der ganze Sinn: Eine Sicherung auf einer immer angeschlossenen Platte oder in einem Cloud-Ordner, den das Bürokonto löschen kann, ist die nächste verschlüsselte Sicherung. Täglich ist der strengste Rhythmus der Formulare und der, den das Toolkit fragt. Der Beispielbetrieb sichert täglich auf ein NAS im Büro ohne Offline-Kopie: „teilweise“, erste Welle.

D2 Wiederherstellung in den letzten zwölf Monaten geprobt, mit notierter Dauer.

FAKT

Mannheimer fragt nach dem Datum des letzten erfolgreichen Rücksicherungstests kritischer Systeme; Markel verlangt mindestens einmal jährlich einen Wiederherstellungstest für alle Datensicherungen; Beazley und Funk wollen Sicherungen, die „regelmäßig getestet“ werden, um sicherzustellen, dass sie wiederherstellbar sind. Die Durchführungsverordnung verlangt „regelmäßige Tests der Wiederherstellung von Sicherungskopien und Redundanzen“.

→ Quelle: Mannheimer, 4.2; Markel, 7.2; Beazley, 1; Funk, 1; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 4.2.6 · abgerufen 19.10.2026

AUSLEGUNG

Die notierte Dauer ist unser Zusatz; sie macht aus dem Test die Antwort auf D3. Ein Ordner zurückgespielt, die Zeit gestoppt, Datum und Ergebnis in einer Zeile: Das ist der Nachweis. Der Beispielbetrieb hat nie geprobt: „noch nicht“, erste Welle.

D3 Wie lange der Betrieb ohne seine IT weiterarbeiten könnte.

FAKT

Mannheimer fragt nach einem Notfall- und Wiederanlaufkonzept; die Durchführungsverordnung verlangt Sicherungspläne mit Wiederherstellungszeiten und einen Notfallplan mit der Reihenfolge der Wiederherstellung; VdS 10000 hat ein Kapitel zum Identifizieren kritischer IT-Ressourcen und eines zu Wiederanlaufplänen; TISAX führt Prüfziele für hohe Verfügbarkeit.

→ Quelle: Mannheimer, 5.10; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 4.1.2 und 4.2.2 Buchst. a; VdS 10000:2025-01, Kapitel 9 und 17.5; ENX, NIS2 fulfilment through TISAX, Tabelle 1 · abgerufen 19.10.2026

AUSLEGUNG

Die Frage wird nicht bewertet; sie setzt Prioritäten. Ein Betrieb, der eine Woche mit Papier und Telefon überbrückt, braucht einen anderen Plan als einer, der nach Stunden steht. Die Antwort kommt in Abschnitt D der Selbstauskunft und auf die Notfallkarte („Wir überbrücken"). Der Beispielbetrieb: einen Tag.

D4 Ein schriftlicher Notfallplan: wen anrufen, was zuerst tun, in welcher Reihenfolge wiederherstellen.

FAKT

Die Frage B14 des Labels lautet: „Haben Sie einen Notfallplan, anhand dessen Sie auf einen IT-Sicherheitsvorfall reagieren?", mit dem Kriterium, dass die Pläne mindestens alle zwei Jahre getestet werden; Markel verlangt einen IT-Notfallplan, der „schriftlich fixiert" ist und „Verantwortliche benennt"; Mannheimer ein Notfall- und Wiederanlaufkonzept; ENISA-Schritt 4 ist „einen Plan für die Reaktion auf Vorfälle entwickeln". Die Durchführungsverordnung verlangt ein Konzept für die Bewältigung von Sicherheitsvorfällen mit Rollen, Verantwortlichkeiten und Verfahren und einen Notfallplan mit Kontaktangaben, Aktivierungsbedingungen und der Reihenfolge der Wiederherstellung.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, B14; Markel, 6.3; Mannheimer, 5.10; ENISA, 12 steps, Schritt 4; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 3.1.1 und 4.1.2 · abgerufen 19.10.2026

AUSLEGUNG

Für einen kleinen Betrieb ist die Notfallkarte der Plan: eine Seite mit der ersten Stunde, den Nummern, den Fristen und dem Ort der Dinge, nach dem Vorbild der IT-Notfallkarte des BSI (Abschnitt 4). Aushängen und datieren ist der Nachweis; eine Übung einmal im Jahr, auch am Schreibtisch, ist der Test, den das Label will. Der Beispielbetrieb hat keinen: „noch nicht", erste Welle.

2.4 E · Updates und Geräte

E1 Updates automatisch innerhalb von Tagen auf jedem Computer, Telefon und Server.

FAKT

Die Frage B9 des Labels fragt, ob alle IT-Systeme und Anwendungen regelmäßig mit Sicherheitsupdates aktualisiert werden, mit dem Kriterium „Kein Sicherheitsupdate darf länger als ein Quartal überfällig sein“. Markel verlangt Sicherheitspatches „innerhalb von vier Wochen“ und kritische ab CVSS 8,0 „unverzüglich“; Mannheimer fragt nach einem Patch-Management-Verfahren „zur automatischen oder zeitnahen Installation“; Allianz nach einem Patch-Management, das werktäglich Sicherheitslücken bewertet, priorisiert und ausrollt; Beazley und Funk nach kritischen Patches „so bald wie möglich“. Die Durchführungsverordnung verlangt, dass „Sicherheitspatches innerhalb einer angemessenen Frist nach ihrer Verfügbarmachung angewendet werden“, vor dem Produktivbetrieb getestet und aus vertrauenswürdigen Quellen. ENISA-Schritt 6 beginnt mit „Software gepatcht und aktuell halten“.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, B9; Markel, 7.3; Mannheimer, 7.1; Allianz, 2.5.3; Beazley; Funk, 5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 6.6.1 Buchst. a bis c; ENISA, 12 steps, Schritt 6 · abgerufen 19.10.2026

AUSLEGUNG

„Innerhalb von Tagen“ ist strenger als das Quartal des Labels und die vier Wochen von Markel; es ist das, was automatische Updates von selbst tun, und automatisch ist der einzige Weg, auf dem ein Betrieb ohne IT-Abteilung mithält. Eine monatliche Prüfung, ob sie gelaufen sind, in einer Zeile notiert, ist der Nachweis. Der Beispielbetrieb: „vorhanden“.

E2 Eine Liste aller Geräte, und jedes Gerät und Programm vom Hersteller noch unterstützt.

FAKT

Die Frage B4 des Labels verlangt ein regelmäßig gepflegtes Verzeichnis aller IT-Assets und -Services inklusive Cloud-Dienste; Markel schließt den Zugriff auf „veraltete Systeme ohne Hersteller-Sicherheitsupdates (z. B. Windows 7/XP/NT)“ aus, außer in einem separaten Netzwerk; Allianz fragt, ob keine Software über ihr End-of-Life-Datum hinaus eingesetzt wird; Beazley und Funk schließen Software ohne Unterstützung aus. Die Durchführungsverordnung verlangt „ein vollständiges, genaues, aktuelles und kohärentes Inventar“ der Anlagen und Werte; Bereich i der Richtlinie nennt das Management von Anlagen.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, B4; Markel, Abschnitt 4 Nr. 6; Allianz, 2.5.1; Beazley; Funk, 5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 12.4.1; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. i · abgerufen 19.10.2026

AUSLEGUNG

Eine Geräteliste mit zehn Zeilen und einer Spalte „unterstützt bis“ beantwortet drei Fragen auf einmal: Inventar, Ende der Unterstützung, und wer was benutzt. Der Beispielbetrieb hat keine schriftliche Liste und einen alten Werkstattrechner: „teilweise“, zweite Welle; der Rechner geht vom Netz oder wird ersetzt.

E3 Schutzsoftware auf jedem Computer; Notebooks und Telefone verschlüsselt.

FAKT

Mannheimer fragt, ob alle IT-Systeme „einen Schutz gegen Schadsoftware mit automatischen Updates“ haben; Markel nach einer Endpoint-Protection-Lösung, die automatisch aktualisiert wird, und nach Anti-Virus mit aktuellen Datenbanken; Beazley und Funk nach Anti-Virus oder Endpoint-Protection auf allen Geräten und dem Scannen eingehender E-Mails. Die Frage B11 des Labels fragt, ob die Systeme auf Malware überwacht werden, B12, ob sensible Daten bei der Übertragung verschlüsselt werden. Die Durchführungsverordnung verlangt den Schutz „vor Schadsoftware und nicht genehmigter Software“ und ein Konzept für Kryptografie; ENISA-Schritt 6 nennt Virenschutz, E-Mail- und Web-Schutz und Verschlüsselung; Bereich h der Richtlinie nennt Kryptografie und Verschlüsselung.

→ Quelle: Mannheimer, 7.2; Markel, Abschnitt 4 Nr. 5 und 7.3; Beazley; Funk, 6 und 7; Cyber Trust Austria, Schema Policy 2026, B11 und B12; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 6.9.1 und 9; ENISA, 12 steps, Schritt 6; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. h · abgerufen 19.10.2026

AUSLEGUNG

Der eingebaute Schutz aktueller Systeme genügt jedem gelesenen Formular; niemand verlangt von einem kleinen Betrieb einen Produktnamen. Die Geräteverschlüsselung von Notebooks und Telefonen ist unsere Lesart von ENISA-Schritt 6 und des VdS-Kapitels zu mobilen Systemen: Ein verlorenes Notebook ohne Verschlüsselung ist eine meldepflichtige Datenpanne, mit Verschlüsselung ein verlorenes Notebook. Der Beispielbetrieb: „vorhanden“.

E4 Für Lieferanten von Software oder Geräten: ein Kontakt für Schwachstellenmeldungen und ein Unterstützungszeitraum für die Produkte.

FAKT

Der Cyber Resilience Act verpflichtet Hersteller von Produkten mit digitalen Elementen, Schwachstellen für den Unterstützungszeitraum zu behandeln, der „mindestens fünf Jahre“ beträgt, außer das Produkt wird voraussichtlich kürzer genutzt; eine zentrale Kontaktstelle zu benennen, über die Nutzer „direkt und schnell“ mit ihnen kommunizieren und Schwachstellen melden können, und die sich nicht auf automatisierte Werkzeuge beschränken darf; eine Richtlinie zur koordinierten Offenlegung von Schwachstellen einzuführen; und Sicherheitsupdates unverzüglich und kostenlos bereitzustellen. Die Verordnung gilt ab 11. Dezember 2027; die Pflicht, aktiv ausgenutzte Schwachstellen zu melden, ab 11. September 2026. Die Durchführungsverordnung verlangt von den erfassten Einrichtungen, Schwachstellen zu verfolgen und die Behebung von Schwachstellen in Lieferantenverträge zu schreiben; Bereich e der Richtlinie nennt „Management und Offenlegung von Schwachstellen“.

→ Quelle: Verordnung (EU) 2024/2847 (Cyber Resilience Act), Art. 13 Abs. 8 und 17, Art. 14, Art. 71, Anhang I Teil II Nr. 2, 5, 6 und 8, Anhang II Nr. 2, englische Fassung; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.1.4 Buchst. f und 6.10; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. e · abgerufen 19.10.2026

◆ AUSLEGUNG

Ein Betrieb, der Software nur benutzt, antwortet „nicht anwendbar“ und verliert nichts. Ein Betrieb, der Geräte oder Software liefert, kann eine Kontaktadresse und eine Angabe zum Unterstützungszeitraum heute veröffentlichen, bevor die Verordnung gilt; beides ist, was Kunden unter der Durchführungsverordnung verlangen müssen. Der Beispielbetrieb installiert, stellt aber nicht her: „nicht anwendbar“.

E5 Router oder Firewall aktuell, Administratorpasswort geändert, Fernadministration aus, getrenntes Gastnetz.

■ FAKT

Mannheimer fragt, ob das Netzwerk segmentiert wurde; Markel verlangt „Firewalls an allen Übergängen in das Internet“; die Frage B7 des Labels verlangt die vom Hersteller empfohlenen Sicherheitseinstellungen, B10 die Sicherung des Netzwerks vor unberechtigtem Zugriff von außen; VdS 10000 nennt Segmentierung und Fernzugang in seinem Netzwerkkapitel; die Durchführungsverordnung verlangt Konfigurationsmanagement, Netzsicherheit und Segmentierung; ENISA-Schritt 7 ist „Ihr Netzwerk sichern“ mit Firewalls und der Überprüfung des Fernzugriffs.

→ Quelle: Mannheimer, 7.4; Markel, Abschnitt 4 Nr. 5; Cyber Trust Austria, Schema Policy 2026, B7 und B10; VdS 10000:2025-01, Kapitel 11.5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 6.3, 6.7 und 6.8; ENISA, 12 steps, Schritt 7 · abgerufen 19.10.2026

◆ AUSLEGUNG

Für einen kleinen Betrieb heißt Segmentierung eines: Besucher und smarte Geräte in einem Gastnetz, das das Büro nicht sieht. Die vier Punkte der Frage prüft ein IT-Dienstleister in einer Stunde. Der Beispielbetrieb hat ein Gastnetz, kennt aber Firmware-Stand und Passwort nicht: „teilweise“, zweite Welle.

2.5 F · Vorfälle und Meldung

F1 Innerhalb welcher Zeit Sie einem Kunden einen Vorfall melden können, der ihn betreffen könnte.

FAKT

Die Durchführungsverordnung erwartet in Lieferantenverträgen „eine Verpflichtung der Anbieter und Diensteanbieter, den betreffenden Einrichtungen Sicherheitsvorfälle, die ein Risiko für die Sicherheit der Netz- und Informationssysteme dieser Einrichtungen darstellen, unverzüglich zu melden“. Erfasste Einrichtungen selbst müssen ihrer Behörde „unverzüglich, in jedem Fall aber innerhalb von 24 Stunden nach Kenntnisnahme“ eine Frühwarnung, binnen 72 Stunden eine Meldung und spätestens einen Monat danach einen Abschlussbericht übermitteln, und gegebenenfalls die Empfänger ihrer Dienste unverzüglich über erhebliche Vorfälle unterrichten, die die Erbringung des Dienstes beeinträchtigen könnten. Ein DORA-Vertrag enthält die Unterstützung bei IKT-Vorfällen. Die Bedingungen des österreichischen Versicherers verlangen die Meldung an den Versicherer „spätestens innerhalb einer Woche ab Kenntnis“.

→ Quelle: Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.1.4 Buchst. d; Richtlinie (EU) 2022/2555, Art. 23 Abs. 1 und 4; Verordnung (EU) 2022/2554, Art. 30 Abs. 2 Buchst. f; Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4 · abgerufen 19.10.2026

AUSLEGUNG

Die eigene Uhr des Kunden beginnt bei 24 Stunden, deshalb sagt eine Klausel „unverzüglich“ oder nennt 24 Stunden. Ein kleiner Betrieb kann einen Anruf der Leitung binnen 24 Stunden nach Kenntnis zusagen; einen schriftlichen Bericht mit Ursache in dieser Zeit kann er nicht zusagen, und D6 sagt das. Die Frage lässt Sie wählen, was Sie halten können; die Notfallkarte zeigt es. Der Beispielbetrieb: 24 Stunden, telefonisch durch die Leitung.

F2 Wer nach einem Vorfall prüft, ob personenbezogene Daten betroffen sind, und wer binnen 72 Stunden an die Datenschutzbehörde meldet.

FAKT

Der Verantwortliche meldet eine Verletzung des Schutzes personenbezogener Daten der Aufsichtsbehörde „unverzüglich und möglichst binnen 72 Stunden, nachdem ihm die Verletzung bekannt wurde“, bei Verspätung mit Begründung; der Auftragsverarbeiter meldet sie dem Verantwortlichen unverzüglich; die Meldung beschreibt die Art der Verletzung, die wahrscheinlichen Folgen und die ergriffenen Maßnahmen. Hat die Verletzung voraussichtlich ein hohes Risiko zur Folge, werden die Betroffenen unverzüglich benachrichtigt, außer unter anderem die Daten waren verschlüsselt. Die österreichische Behörde bietet ein Online-Formular, ein PDF-Formular und eine E-Mail-Adresse; in Deutschland sind die Landesbehörden zuständig.

→ Quelle: Verordnung (EU) 2016/679, Art. 33 Abs. 1 bis 3, Art. 34 Abs. 1 und Abs. 3 Buchst. a, deutsche und englische Fassung; Datenschutzbehörde, Meldung Data Breach; BfDI, Landesbehörden · abgerufen 19.10.2026

◆ AUSLEGUNG

Die 72 Stunden sind die härteste Frist, die ein kleiner Betrieb kennt; sie laufen ab Kenntnis, über Wochenenden, und die erste Entscheidung, ob personenbezogene Daten betroffen sind, braucht eine benannte Person. Diese Person und die meldende Person stehen auf der Notfallkarte. Der Beispielbetrieb kennt die Pflicht, hat aber niemanden benannt: „teilweise", erste Welle.

F3 Vorfälle der letzten 24 Monate.

■ FAKT

Versicherungsanträge fragen nach früheren Vorfällen, und die vorvertragliche Anzeigepflicht des Antragstellers ist der rechtliche Grund: Mannheimers Formular verweist auf § 19 Abs. 5 des deutschen Versicherungsvertragsgesetzes. Zwei deutsche Gerichte haben über Cyberpolicen entschieden, bei denen die Antworten im Antrag nicht zu den Tatsachen passten.

→ Quelle: Mannheimer, Abschnitt 15; LG Kiel, Urteil vom 23.5.2024, 5 O 128/21; OLG Schleswig, Urteil vom 8.1.2025, 16 U 63/24, beide nur aus Sekundärquellen bekannt · abgerufen 19.10.2026

◆ AUSLEGUNG

Die Frage hat in den drei EU-Rechtsakten keine Grundlage; sie steht, weil jeder Versicherer fragt und ein Kunde fragen kann. Die ehrliche Antwort ist eine von drei: keine, ja behoben und dokumentiert, unbekannt. „Unbekannt" ist eine legitime Antwort für einen Betrieb, der nie ein Protokoll geführt hat; sie wird „keine" oder „ja", sobald das Protokoll existiert (F4). Die 24 Monate sind der übliche Zeitraum der Formulare, kein Rechtsbegriff. Der Beispielbetrieb: keine.

F4 Vorfälle werden aufgeschrieben: was passiert ist, auf welchem Weg, was gefehlt hat, was geändert wurde.

■ FAKT

Die DSGVO verlangt vom Verantwortlichen die Dokumentation von Verletzungen „einschließlich aller im Zusammenhang mit der Verletzung des Schutzes personenbezogener Daten stehenden Fakten, ihrer Auswirkungen und der ergriffenen Abhilfemaßnahmen". Die Frage B13 des Labels verlangt die Protokollierung der Nutzung der IT-Systeme, um Vorfälle nachvollziehbar zu machen; die Durchführungsverordnung verlangt ein Konzept für die Bewältigung von Vorfällen mit „Dokumentation und Meldung", Protokollierung und Überprüfungen nach Vorfällen.

→ Quelle: Verordnung (EU) 2016/679, Art. 33 Abs. 5; Cyber Trust Austria, Schema Policy 2026, B13; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 3.1.1, 3.2 und 3.6 · abgerufen 19.10.2026

◆ AUSLEGUNG

Eine Seite je Vorfall, angelegt auch wenn sie leer bleibt, ist das Protokoll. Die technische Protokollierung der Server (das Label will neunzig Tage) ist der Teil des IT-Dienstleisters; der Teil des Betriebs ist die Seite. Der Beispielbetrieb: „noch nicht", zweite Welle.

2.6 G · Personal

G1 Einweisung in den letzten zwölf Monaten zu Phishing, Passwörtern und dem Meldeweg, mit Teilnehmerliste.

FAKT

Mannheimer fragt, ob die Mitarbeiter „mindestens jährlich über Maßnahmen zur IT-Sicherheit geschult“ werden; Markel nach regelmäßigen, „mindestens jährlich“ durchgeführten Sensibilisierungs- und Schulungsmaßnahmen zu Informationssicherheit, aktuellen Cyberbedrohungen und Datenschutz; Beazley und Funk nach jährlichen Schulungen „einschließlich Anti-Phishing“ für alle mit Zugang zum Netzwerk oder zu vertraulichen Daten. Die Frage B2 des Labels fragt, ob die Mitarbeiter regelmäßig geschult werden; die Durchführungsverordnung verlangt, dass die Mitarbeitenden „einschließlich der Mitglieder von Leitungsorganen“ sich der Risiken bewusst sind und Cyberhygiene anwenden; Bereich g der Richtlinie nennt Cyberhygiene und Schulungen; ENISA-Schritt 2 ist „angemessene Schulung anbieten“.

→ Quelle: Mannheimer, 5.4; Markel, 6.4; Beazley, 4; Funk, 4; Cyber Trust Austria, Schema Policy 2026, B2; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 8.1.1; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. g; ENISA, 12 steps, Schritt 2 · abgerufen 19.10.2026

AUSLEGUNG

Eine halbe Stunde zu Beginn einer Teambesprechung, mit den vier Themen und einer Liste, wer da war, ist die Schulung, die jedes Formular annimmt; die Liste ist der Nachweis, deshalb fragt die Frage danach. Der Beispielbetrieb hat noch keine gehalten: „noch nicht“, zweite Welle.

G2 Beschäftigte schriftlich zur Vertraulichkeit verpflichtet.

FAKT

Die DSGVO verlangt, dass der Auftragsverarbeiter gewährleistet, „dass sich die zur Verarbeitung der personenbezogenen Daten befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen“. Die Durchführungsverordnung verlangt Sicherheit des Personals und dass Pflichten, die nach dem Ende des Beschäftigungsverhältnisses fortgelten, vertraglich festgelegt sind; das Österreichische Informationssicherheitshandbuch hat ein Kapitel zur personellen Sicherheit.

→ Quelle: Verordnung (EU) 2016/679, Art. 28 Abs. 3 Buchst. b; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 10.1 und 10.3.1; Österreichisches Informationssicherheitshandbuch, Version 4.4.0, Kapitel 7 · abgerufen 19.10.2026

AUSLEGUNG

Kein gelesener Fragebogen fragt das mit diesen Worten; die Frage steht, weil der Auftragsverarbeitungsvertrag, den Ihr Kunde mit Ihnen schließt, es in Ihrem Namen zusagt. Eine Klausel im Dienstvertrag oder ein unterschriebener Zusatz genügt. Der Beispielbetrieb: „vorhanden“.

G3 Eine Zahlungsregel: Jede Änderung von Bankdaten und jede ungewöhnliche Zahlungsaufforderung wird per Rückruf unter einer bekannten Nummer bestätigt.

FAKT

Das österreichische Bundeskriminalamt empfiehlt gegen CEO Fraud und Business E-Mail Compromise: „Vier-Augen-Prinzip bei Zahlungen einführen", mehrstufige Freigabeprozesse, „Bankdatenänderungen ausschließlich über bekannte Kontaktwege verifizieren", „Rückrufverfahren etablieren", und stellt fest: „Änderungen von Kontoverbindungen sollten niemals ausschließlich aufgrund einer E-Mail durchgeführt werden!" Die Wirtschaftskammer Oberösterreich warnt vor Rechnungen mit vertauschter IBAN und rät, bei angeblicher Änderung der Kontodaten „nicht nur per E-Mail, sondern auch telefonisch rückzufragen", vor der Überweisung, unter einer schon bekannten Nummer, mit einer zweiten Person, die Zahlungsaufträge prüft. Der ENISA-Bericht für KMU beschreibt das gekaperte Postfach als Einstieg in diesen Betrug.

→ Quelle: Bundeskriminalamt, CEO Fraud / Business E-Mail Compromise, Stand 29.6.2026; Wirtschaftskammer Oberösterreich, Betrug mit geänderten Kontodaten, 22.7.2025; ENISA, Cybersecurity for SMEs, Juni 2021 · abgerufen 19.10.2026

AUSLEGUNG

Das ist die eine Frage, die kein Sicherheitsfragebogen stellt und die kleine Betriebe das meiste Geld kostet. Sie hat Priorität 1, weil sie keine Technik braucht: eine Regel, eine bekannte Nummer, zwei Personen. Der Beispielbetrieb: „vorhanden".

2.7 H · Eigene Dienstleister und Cloud

H1 Eine Liste der Dienstleister, die Ihre Daten oder die Ihrer Kunden verarbeiten, mit Land und Zweck.

FAKT

Die Durchführungsverordnung verlangt „ein Verzeichnis ihrer direkten Anbieter und Diensteanbieter" mit Kontaktstellen und der Liste der Produkte und Dienste, die jeder liefert; die Frage A11 des Labels verlangt einen Prozess zum Management der Lieferantenrisiken; ENISA-Schritt 3 ist „wirksames Management Dritter sicherstellen"; Bereich d der Richtlinie nennt die unmittelbaren Anbieter und Diensteanbieter. Das Verzeichnis von Verarbeitungstätigkeiten der DSGVO gilt nicht für Unternehmen mit weniger als 250 Mitarbeitern, es sei denn, die Verarbeitung erfolgt nicht nur gelegentlich, was bei E-Mail und Dateiablage der Fall ist.

→ Quelle: Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.2; Cyber Trust Austria, Schema Policy 2026, A11; ENISA, 12 steps, Schritt 3; Richtlinie (EU) 2022/2555, Art. 21 Abs. 2 Buchst. d; Verordnung (EU) 2016/679, Art. 30 Abs. 1 und 5 · abgerufen 19.10.2026

◆ AUSLEGUNG

Fünf bis zehn Zeilen: E-Mail, Dateiablage, Buchhaltung, Website, der IT-Dienstleister; mit Land, Zweck, Vertrag und Kontakt. Die Liste beantwortet die Frage des Kunden nach Unterauftragnehmern (D6), bevor sie gestellt wird. Der Beispielbetrieb hat die Liste im Kopf: „teilweise".

H2 Auftragsverarbeitungsverträge mit diesen Dienstleistern, und deren Sicherheitseinstellungen eingeschaltet.

■ FAKT

Ein Verantwortlicher arbeitet nur mit Auftragsverarbeitern, die hinreichend Garantien bieten, und die Verarbeitung erfolgt auf Grundlage eines Vertrags mit den Inhalten des Art. 28 Abs. 3. Beazley und Funk verlangen MFA für Cloud-basierte Dienste; die Durchführungsverordnung verlangt von den erfassten Einrichtungen Cybersicherheitsanforderungen in Lieferantenverträgen und Sicherheit beim Erwerb von IKT-Diensten; ENISA-Schritt 10 ist „die Cloud bewusst nutzen".

→ Quelle: Verordnung (EU) 2016/679, Art. 28 Abs. 1 und 3; Beazley, 2; Funk, 2; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.1.4 Buchst. a und 6.1; ENISA, 12 steps, Schritt 10 · abgerufen 19.10.2026

◆ AUSLEGUNG

Die großen Anbieter bieten den Vertrag als Klick in der Administrationskonsole; der Nachweis ist die heruntergeladene Kopie. „Eine zweite Administratorin" ist unser Zusatz: Ein Cloud-Konto mit einer einzigen Administratorin, die geht, das Passwort vergisst oder das Telefon verliert, ist ein ausgesperrter Betrieb. Der Beispielbetrieb: Verträge ja, Konsoleneinstellungen ungeprüft: „teilweise".

H3 Der Kunde wird informiert, bevor ein Dienstleister gewechselt wird, der seine Daten verarbeitet.

■ FAKT

Die Durchführungsverordnung erwartet in Lieferantenverträgen Anforderungen an die Unterauftragsvergabe und an Unterauftragnehmer; ein DORA-Vertrag nennt die Orte der Verarbeitung und verlangt die Vorabinformation bei deren Änderung; nach der DSGVO nimmt ein Auftragsverarbeiter „keinen weiteren Auftragsverarbeiter ohne vorherige gesonderte oder allgemeine schriftliche Genehmigung des Verantwortlichen in Anspruch" und informiert bei allgemeiner Genehmigung „über jede beabsichtigte Änderung", damit der Verantwortliche Einspruch erheben kann.

→ Quelle: Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.1.4 Buchst. g; Verordnung (EU) 2022/2554, Art. 30 Abs. 2 Buchst. a und b; Verordnung (EU) 2016/679, Art. 28 Abs. 2 · abgerufen 19.10.2026

◆ AUSLEGUNG

Die Regel kostet eine E-Mail-Vorlage. Der Beispielbetrieb hat keine: „noch nicht", dritte Welle.

2.8 I · Nachweise, Termine und Wiedervorlage

I1 Am Ende eines Vertrags werden die Daten des Kunden zurückgegeben oder gelöscht, und Sie können das schriftlich bestätigen.

FAKT

Die Durchführungsverordnung nennt „Pflichten der Anbieter und Diensteanbieter bei Vertragskündigung, z. B. Abruf und Entsorgung der Informationen“; DORA nennt Zugang, Wiederherstellung und Rückgabe der Daten; der Auftragsverarbeitungsvertrag nach der DSGVO sieht vor, dass der Auftragsverarbeiter nach Abschluss der Leistungen alle personenbezogenen Daten löscht oder zurückgibt.

→ Quelle: Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 5.1.4 Buchst. h; Verordnung (EU) 2022/2554, Art. 30 Abs. 2 Buchst. d; Verordnung (EU) 2016/679, Art. 28 Abs. 3 Buchst. g · abgerufen 19.10.2026

AUSLEGUNG

Eine Regel von einem Absatz und eine Bestätigungsvorlage beantworten die Klausel. Der Beispielbetrieb: „vorhanden“.

I2 bis I4 Datum der Selbstauskunft, erste Welle, Überprüfung. Das Datum auf D1 und D7 (I2), der Termin der ersten Maßnahmenwelle (I3; die zweite und dritte Welle folgen zwei und fünf Monate später) und der Prüfrhythmus von sechs oder zwölf Monaten (I4).

FAKT

Das österreichische Label gilt ein Jahr; VdS-Zertifikate werden jährlich nachgeprüft; Mannheimer fragt, ob der Betrieb regelmäßig Analysen durchführt; die Durchführungsverordnung verlangt die regelmäßige Überprüfung der Einhaltung und Berichte an die Leitung.

→ Quelle: Cyber Trust Austria, Schema Policy 2026, Abschnitt 4.6; VdS 5569, S. 9; Mannheimer, 5.3; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 2.2.1 · abgerufen 19.10.2026

AUSLEGUNG

Zwölf Monate sind der Rhythmus jedes gelesenen Schemas; sechs für einen Betrieb, der viele offene Punkte abarbeitet. Das Prüfdatum steht auf D7 und auf dem Blatt Wiedervorlage von D2 mit vier Anlässen: ein neuer Kundenfragebogen, ein Austritt, ein neuer Dienstleister, ein Vorfall.

3 Nachweise

Was ein Fragebogen annimmt. Niemand prüft einen Zehn-Personen-Lieferanten vor Ort; die prüfende Person will je Antwort ein datiertes Dokument, das man zeigen könnte, wenn jemand fragt. Die Nachweisliste (D4) nennt je Frage eines, gibt ihm eine Anlagennummer, wenn es vorliegt, und ein Datum und einen Satz, wie es entsteht, wenn nicht. Die Anlagen liegen im Ordner aus Frage A8; D1 und D5 verweisen auf die Nummern.

Wie jeder Nachweis in einer Stunde oder weniger entsteht. Die Kontenliste mit täglichen und Administratorkonten (C1, C4, C5): eine Tabelle, aus den vorhandenen Systemen abgeschrieben. Bildschirmfotos der MFA-Einstellungen oder der Administratorbericht (C2, C3, H2): eines je System. Die schriftlichen Regeln (B1, C6, G3, H3, I1): zwei Seiten, unterschrieben. Die Sicherungseinstellungen und der Ort der Kopie außer Reichweite (D1): ein Bildschirmfoto und ein Satz. Das Protokoll des Wiederherstellungstests (D2): eine Zeile mit Datum, Dauer und Ergebnis. Die Notfallkarte (D4, F2): gedruckt, datiert, ausgehängt. Die Update-Prüfung (E1): eine Zeile im Monat. Die Geräteliste (E2, E3): eine Tabelle mit „unterstützt bis“ und einer Spalte Verschlüsselung. Die Router-Prüfung (E5): Datum und Einstellungen. Das Vorfallsprotokoll (F4): eine Seite, angelegt. Die Teilnehmerliste (G1): Datum, Themen, Namen. Die Vertraulichkeitsklausel (G2): die Vertragsseite oder der Zusatz. Die Dienstleisterliste (H1): eine Tabelle. Die Verträge (H2): die heruntergeladenen Kopien. Eine Police oder ein Zertifikat (B2, B3): das Dokument selbst.

◆ AUSLEGUNG

Dreizehn davon stammen aus dem alten Lieferanten-Antwortkit und werden von Kunden und Versicherern in der Praxis angenommen; keiner braucht ein Werkzeug, das Sie nicht schon haben. Was Sie am Tag nicht zeigen können, kommt mit dem Termin aus dem Maßnahmenplan in D4, und das Antwortschreiben sagt es. Das unterscheidet eine Selbstauskunft von einem Fragebogen, der durchgehend mit „Ja“ beantwortet ist.

Anlagennummern und der Ordner. D4 nummeriert nur, was vorliegt; eine Lücke behält ihre Fragennummer und ihren Termin. Der Ordner aus A8 enthält die Anlagen, die Selbstauskunft, den Plan, die Karte und die Nachweisseite, und sein Pfad steht auf der Notfallkarte, damit die Vertretung ihn findet. Halten Sie den Ordner außerhalb der Systeme, die verschlüsselt werden könnten, oder halten Sie dort eine Kopie.

Die Überprüfung. Am Datum in D7 öffnet der Betrieb den Generator, ändert, was sich geändert hat, und friert eine neue Fassung ein; das Konto bewahrt jede eingefrorene Fassung mit Datum auf und zeigt, welche älter ist als eine Aktualisierung des Toolkits. Das Blatt Wiedervorlage von D2 nennt die vier Anlässe, die den Termin vorziehen.

4 Der Notfall

4.1 Die erste Stunde

FAKT

Das Sicherheitsportal des Bundeskanzleramts rät, dass ein infizierter Computer „sofort abgewürgt, also stromlos gemacht werden“ sollte, dass Fachleute von der Zahlung des Lösegelds abraten und dass der Vorfall „in der nächsten Polizeidienststelle“ gemeldet werden soll. Die zwölf Fragen des BSI für die erste Reaktion fragen, ob betroffene Systeme und die Internetverbindung getrennt wurden, ob Backups gestoppt und vor weiteren Einwirkungen geschützt wurden, ob Protokolle, Notizen und Fotos von Bildschirminhalten gesichert wurden, ob Polizei oder Behörden nach Abstimmung benachrichtigt wurden und ob Zugangsberechtigungen geprüft wurden. Die IT-Notfallkarte des BSI, „analog zum bekannten Format ‚Verhalten im Brandfall‘“, trägt drei Botschaften: Ansprechpartner und Erreichbarkeit kennen, entscheidende Informationen sofort weitergeben, Gegenmaßnahmen nur nach Absprache.

→ Quelle: onlinesicherheit.gv.at, Erpressungstrojaner, Stand 23.7.2022; BSI und Partner, TOP 12 Maßnahmen bei Cyber-Angriffen, September 2019; BSI und Allianz für Cyber-Sicherheit, IT-Notfallkarte · abgerufen 19.10.2026

AUSLEGUNG

Die Karte fasst das in vier Handgriffe: trennen, nicht löschen und die Sicherung nicht anstecken, anrufen, aufschreiben. Beim Ausschalten widersprechen sich die Quellen: Das österreichische Portal sagt stromlos machen, die Liste des BSI will Spuren gesichert. Die Karte sagt: nicht ausschalten, wenn in Kürze Hilfe kommt, weil Spuren verloren gehen; ausschalten, wenn niemand kommt und sich die Verschlüsselung sichtbar ausbreitet. Kein Lösegeld ohne Rücksprache mit Polizei und Versicherer; eine Zahlung garantiert nichts. Alles auf der Karte muss auf Papier stehen, weil der Computer das sein kann, was verschlüsselt ist.

4.2 Fristen

Personenbezogene Daten: 72 Stunden. Abschnitt 2.5, F2. Die Uhr beginnt, wenn der Betrieb Kenntnis erlangt; die benannte Person entscheidet am ersten Tag, ob personenbezogene Daten betroffen sind; die Meldung geht an die Behörde des Landes (Abschnitt 5); die Betroffenen werden benachrichtigt, wenn das Risiko hoch ist.

Kunden unter NIS 2. Abschnitt 2.5, F1. Die Frühwarnung Ihres Kunden ist binnen 24 Stunden nach seiner eigenen Kenntnis fällig; Ihr Anruf ist es, der seine Uhr startet. Ist Ihr Betrieb selbst von NIS 2 erfasst (das freie NIS2-Memo auf scutoria.com sagt es in fünf Fragen), gelten dieselben Fristen für Sie gegenüber Ihrer Behörde.

Versicherer, Bank, Polizei. Die Police nennt ihre Frist; die gelesenen österreichischen Bedingungen sagen eine Woche. Nach einer betrügerischen Überweisung sagt das

Bundeskriminalamt: unverzüglich die Hausbank kontaktieren, den Rückruf der Zahlung beantragen, E-Mails und Bildschirmfotos sichern, bei der Polizeidienststelle Anzeige erstatten.

→ Quelle: Donau Versicherung, AVB Cyber 2025, Teil D 7.1.4; Bundeskriminalamt, CEO Fraud, Stand 29.6.2026 · abgerufen 19.10.2026

4.3 Danach

FAKT

Die DSGVO verlangt die Dokumentation der Verletzung mit Fakten, Auswirkungen und Abhilfemaßnahmen; die Durchführungsverordnung verlangt Überprüfungen nach Vorfällen. Die BSI-Liste endet mit der Prüfung der Zugangsberechtigungen: neue Passwörter, zweiter Faktor.

→ Quelle: Verordnung (EU) 2016/679, Art. 33 Abs. 5; Durchführungsverordnung (EU) 2024/2690, Anhang Nr. 3.6; BSI, TOP 12 · abgerufen 19.10.2026

AUSLEGUNG

Von einem sauberen Gerät aus: die Passwörter von E-Mail, Bank und Cloud ändern, den zweiten Faktor prüfen, die eine Seite für das Vorfallsprotokoll schreiben (F4). Die Seite ist auch das, was Versicherer und Kunde verlangen werden, und sie macht die nächste Selbstauskunft wahr.

5 Ländernotizen

Die Unionsregeln der Abschnitte 1, 2 und 4 gelten in jedem Mitgliedstaat. Was sich unterscheidet, sind Behörde, Hotline, Polizeikontakt und das nationale Gütesiegel oder der Check. Die Notfallkarte nimmt die Kontakte aus Frage A2.

5.1 Österreich

FAKT

Das NISG 2026 gilt in seinen Kernteilen seit 1. Oktober 2026; die Cybersicherheitsbehörde ist das Bundesamt für Cybersicherheit; erfasste Einrichtungen registrieren sich bis 1. Januar 2027, übermitteln binnen zwölf Monaten nach Eintritt der Registrierungspflicht eine Selbstdeklaration und können frühestens zwei Jahre nach Inkrafttreten des Gesetzes zu einer Prüfung aufgefordert werden; die NISV 2026 vom 1. Oktober 2026 macht den Anhang der Durchführungsverordnung zum Katalog für alle. Die Cyber-Security-Hotline der Wirtschaftskammern antwortet unter 0800 888 133 „Montag bis Sonntag, 0 – 24 Uhr“, für Mitglieder kostenlos, mit einem kostenlosen Erstgespräch eines IT-Security-Unternehmens. CERT.at nimmt Meldungen unter

reports@cert.at

und +43 1 5056416 78 entgegen. Der Polizei-Notruf ist 133, der Euro-Notruf 112; das Bundeskriminalamt nimmt Hinweise unter

against-cybercrime@bmi.gv.at

entgegen, aber keine Anzeige, die bei einer Polizeidienststelle erstattet wird. Die Datenschutzbehörde nimmt Meldungen per Online-Formular, PDF-Formular oder E-Mail an

dsb@dsb.gv.at

entgegen, „unverzüglich und möglichst binnen 72 Stunden“. Das Österreichische Informationssicherheitshandbuch, Version 4.4.0 vom 6. November 2023 von Bundeskanzleramt und A-SIT, ist frei und folgt ISO 27001 in achtzehn Kapiteln.

→ Quelle: NISG 2026, §§ 29, 32, 33; NISV 2026, § 2; Bundesamt für Cybersicherheit; WKO, Cyber-Security-Hotline, 1.6.2026; CERT.at; polizei.gv.at, Notrufnummern; Bundeskriminalamt, Meldestellen; Datenschutzbehörde, Meldung Data Breach; sicherheitshandbuch.gv.at · abgerufen 19.10.2026

AUSLEGUNG

Für einen österreichischen Lieferanten ist das Label (Abschnitt 1.5) der natürliche zweite Schritt, wenn ein Kunde mehr will als die Selbstauskunft; seine vierzehn Standard-Fragen überschneiden sich mit den Blöcken B bis H dieses Toolkits, die Antworten hier sind also die Antworten dort.

5.2 Deutschland

FAKT

Das geänderte BSI-Gesetz ist seit 6. Dezember 2025 in Kraft; erfasste Einrichtungen mussten sich binnen drei Monaten beim BSI registrieren, und das BSI bietet eine Betroffenheitsprüfung an. Das BSI veröffentlicht den CyberRisikoCheck für kleine Betriebe, die IT-Notfallkarte und mit der Allianz für Cyber-Sicherheit die TOP 12 Maßnahmen; die Polizei jedes Bundeslands führt eine Zentrale Ansprechstelle Cybercrime für Unternehmen, Liste bei polizei.de; der Polizei-Notruf ist 110; die Datenschutzbehörden für nicht-öffentliche Stellen sind die der Länder, Liste beim Bundesbeauftragten. VdS 10000 ist der KMU-Standard, den Versicherer nennen.

→ Quelle: BSI-Gesetz, in Kraft 6.12.2025; BSI, NIS-2-Seiten, CyberRisikoCheck, IT-Notfallkarte; polizei.de, ZAC; BfDI, Landesbehörden; VdS · abgerufen 19.10.2026

AUSLEGUNG

Ein deutscher Lieferant außerhalb der digitalen Sektoren ist an die Durchführungsverordnung nicht gebunden, aber die Prüfer seiner Kunden lesen sie; die acht Vertragsinhalte von D6 sind deshalb genauso nützlich. Der CyberRisikoCheck ist die billigste externe Prüfung und fragt in seinen sechs Bereichen, was die Blöcke B bis H fragen.

5.3 Andere Mitgliedstaaten

LÜCKE

Das Toolkit hat Behörden, Hotlines und Gütesiegel anderer Mitgliedstaaten nicht erhoben. Was überall gilt: die Richtlinie in ihrer Umsetzung, die Durchführungsverordnung für digitale Anbieter, DORA für Finanzkunden, die 72 Stunden der DSGVO, der Cyber Resilience Act. Die Notfallkarte für ein anderes EU-Land nennt den Euro-Notruf 112, das nationale Computer-Notfallteam (ENISA führt eine Liste) und die nationale Datenschutzbehörde und lässt die Hotline offen. Ein Betrieb anderswo füllt die drei Felder aus seiner eigenen Kammer oder Behörde.

6 Offene Punkte

Das alte Lieferanten-Antwortkit vom September 2026 führte sechzehn Unsicherheiten. Jede wurde am 19. Oktober 2026 am Original nachgeprüft; die Tabelle sagt, was sich geändert hat. Sieben neue Punkte kamen dazu.

Nr.	Frage	Stand 19. Oktober 2026
6.1	Wurde der Wortlaut von Richtlinie, DORA und Durchführungsverordnung am Amtsblatt gelesen?	Erledigt. Alle drei bei EUR-Lex auf Englisch gelesen, Richtlinie und Durchführungsverordnung auch auf Deutsch; die Zitate in den Abschnitten 1 und 2 stammen aus den Originalen.
6.2	Wurden §§ 32 und 33 NISG 2026 gelesen?	Erledigt. Im Bundesgesetzblatt vom 23. Dezember 2025 gelesen; Abschnitt 1.1 zitiert sie.

Nr.	Frage	Stand 19. Oktober 2026
6.3	Wann beginnt die Zwölfmonatsfrist für die österreichische Selbstdeklaration?	Teilweise. § 33 Abs. 1 sagt „nach Eintritt der Registrierungspflicht“; die erste Prüfaufforderung kommt frühestens zwei Jahre nach Inkrafttreten. Die alte Prognose, dass Fragebögen „in das Jahr 2027 fallen“, bleibt eine Markterwartung.
6.4	Hat die österreichische Behörde die Durchführungsverordnung auf weitere Sektoren erstreckt?	Erledigt. Ja: NISV 2026, § 2, vom 1. Oktober 2026. Die acht Vertragsinhalte sind das Muster für jeden österreichischen NIS-2-Kunden.
6.5	Wurde der Cyber Resilience Act am Original gelesen?	Erledigt. Englische Amtsblattfassung gelesen; der Unterstützungszeitraum von mindestens fünf Jahren und die zentrale Kontaktstelle sind in Abschnitt 2.4 belegt. Deutscher Wortlaut nicht gelesen.
6.6	Gibt es einen amtlichen Muster-Lieferantenfragebogen?	Offen. Keiner gefunden; die Fragen folgen den je Frage genannten Quellen, und sechs Versichererformulare wurden im Wortlaut gelesen.
6.7	Welche Fragen haben keine öffentliche Quelle?	Eingegrenzt. Die Cyberversicherung (B2) bleibt ohne Rechtsgrundlage und ist so markiert; frühere Vorfälle (F3) stützen sich auf die Anzeigepflicht und die Versichererpraxis; die Vertraulichkeit (G2) jetzt auf Art. 28 Abs. 3 Buchst. b DSGVO; die Zahlungsregel (G3) auf Bundeskriminalamt und Wirtschaftskammer.
6.8	Stammen die sechs Themenbereiche der DIN SPEC 27076 aus der Spezifikation?	Teilweise. Sie stammen aus dem BVMW-Leitfaden vom August 2023, den BSI-Mitarbeiter mitverfasst haben; die Spezifikation selbst liegt hinter einer kostenlosen Anmeldung und wurde nicht gelesen.
6.9	Ist der GDV-Musterfragebogen vollständig bekannt?	Ersetzt. Stattdessen wurden sechs öffentliche Versichererformulare ganz gelesen; das GDV-Muster wurde nicht weiterverfolgt.
6.10	Wird aus ISO/IEC 27001 mehr behauptet als die Struktur?	Nein. Das Handbuch nennt die 93 Maßnahmen in vier Themen aus dem Journal des Normenausschusses und behauptet keinen Inhalt der kostenpflichtigen Norm.
6.11	Kriterien, Kosten und Dauer von Gütesiegeln und Zertifikaten?	Für das österreichische Label erledigt: Fragen und Preise in der Schema Policy und auf der Website gelesen; ob ein namentlicher Kunde es verlangt, wurde nicht gefunden. Kosten einer ISO-Zertifizierung für kleine Betriebe nicht erhoben.
6.12	Zahlen der ENISA-Erhebung?	Gestrichen. Das Handbuch zitiert sie nicht mehr.
6.13	Zahl der Felder der Selbstauskunft?	Geschlossen. Das Toolkit stellt vierzig Fragen, 24 davon Statusfragen.
6.14	Delegierte Verordnung (EU) 2025/532, Durchführungsverordnung (EU) 2024/2956, die Vertragsinhalte der deutschen Finanzaufsicht, die DORA-Musterklauseln des GDV, die Seiten der österreichischen Finanzmarktaufsicht?	Offen. Nur als Titel bekannt; Teil B von D6 stützt sich auf Art. 30 DORA selbst. Dass Auftraggeber anderer Sektoren die acht Inhalte der Durchführungsverordnung übernehmen, bleibt eine Einordnung, für Österreich jetzt durch die NISV 2026 gestützt.

Nr.	Frage	Stand 19. Oktober 2026
6.15	Ist im Einzelfall ein Auftragsverarbeitungsvertrag nötig?	Absichtlich offen. Eine Rechtsfrage des Einzelfalls, die das Toolkit nicht beantwortet; H2 fragt, ob die Verträge dort vorliegen, wo personenbezogene Daten verarbeitet werden.
6.16	Passt der Wortlaut zum Begleithandbuch des alten Kits?	Erledigt. Jenes Handbuch wurde nie ausgeliefert; dieses Handbuch ist jetzt der Haupttext und verweist auf kein anderes.
6.17	Neu: regelmäßiger Passwortwechsel.	Die Durchführungsverordnung verlangt Wechsel in festgelegten Zeitabständen; NIST und BSI raten ab. Abschnitt 2.2, Kasten.
6.18	Neu: die Rechtsverweise des österreichischen Labels.	Seine Schema Policy nennt § 11 NISV und § 17 Abs. 3 NISG des früheren Gesetzes; seine Website § 33 NISG 2026. Nicht beim Herausgeber geklärt.
6.19	Neu: die aktuelle Fassung des Katalogs VDA ISA.	vda.de nennt Version 7 und ISA 2027.1; enx.com führt ISA 6.0.3 als aktuell. Nicht aufgelöst.
6.20	Neu: Listenpreis und Volltext von VdS 10000.	Nur ein sechsseitiger Auszug mit Inhaltsverzeichnis lag vor.
6.21	Neu: der Wortlaut der §§ 3 bis 5 NISV 2026.	Als Zusammenfassung des Abrufs gelesen, nicht im Wortlaut; Abschnitt 1.6 paraphrasiert § 4.
6.22	Neu: ob ein Gericht über den Passwort-Widerspruch oder über „unverzüglich“ bei kleinen Lieferanten entschieden hat.	Nicht gesucht.
6.23	Neu: die deutschen Gerichtsentscheidungen zu Cyberversicherungsanträgen.	Nur aus Sekundärquellen bekannt; in Abschnitt 2.5 so zitiert.

7 Glossar

Anlagen- und Werteinventar. Die Liste aller Geräte, Systeme und Dienste, mit wer was benutzt und bis wann es unterstützt wird; Frage E2 und Nr. 12.4.1 der Durchführungsverordnung.

Wiederanlaufzeit. Wie lange der Betrieb ohne seine IT überbrückt (Frage D3) und wie lange eine Wiederherstellung dauert (D2). Fragebögen nennen es RTO.

Multi-Faktor-Authentifizierung (MFA). Anmeldung mit einem zweiten Faktor neben dem Passwort: eine App, ein Sicherheitsschlüssel, als letzte Möglichkeit ein Code per SMS. Fragen C2 und C3.

Phishing-resistent. Ein Anmeldeverfahren, das sich von einer gefälschten Seite nicht täuschen lässt: ein Sicherheitsschlüssel oder ein Passkey, wie NIST und CISA es reihen.

Privilegiertes Konto. Ein Konto mit Administratorrechten; getrennt vom täglichen Konto geführt (C5).

Segmentierung. Die Aufteilung eines Netzwerks, damit Besucher und Geräte ohne Zugriffsbedarf die Bürosysteme nicht erreichen; das Gastnetz aus Frage E5.

Sicherung außer Reichweite. Eine Kopie, die ein Angreifer mit den Rechten des Büros nicht löschen oder verschlüsseln kann: offline, gewechselt oder unveränderbar (D1).

Wiederherstellungstest. Echte Daten aus der Sicherung zurückspielen und Datum, Dauer und Ergebnis notieren (D2).

Auftragsverarbeitungsvertrag. Der Vertrag nach Art. 28 Abs. 3 DSGVO zwischen Verantwortlichem und Auftragsverarbeiter (H2).

Unterauftragnehmer. Ein Dienstleister, den Ihr Dienstleister nutzt, oder ein Dienstleister, den Sie für die Daten des Kunden nutzen; Kunden wollen von Wechseln erfahren (H3).

Prüfrecht. Die Klausel, nach der ein Kunde prüfen oder Prüfberichte erhalten darf; Nr. 5.1.4 Buchst. e der Durchführungsverordnung und Art. 30 Abs. 3 Buchst. e DORA; D6 sagt, was ein kleiner Betrieb annehmen kann.

Wesentliche und wichtige Einrichtung. Die zwei Klassen der von NIS 2 erfassten Betriebe; die Kunden, die Fragebögen schicken.

Betreffende Einrichtungen. Die digitalen Anbieter, die die Durchführungsverordnung unmittelbar bindet; in Österreich durch die NISV 2026 jede NIS-2-Einrichtung.

Selbstauskunft, Selbstdeklaration. D1 dieses Toolkits; auch die Stufe Standard des österreichischen Labels und die Eingabe nach § 33 NISG 2026, die andere Dokumente sind.

Erheblicher Sicherheitsvorfall. Nach der Durchführungsverordnung ein Vorfall mit einem Verlust über 500.000 Euro oder fünf Prozent des Umsatzes, neben anderen Kriterien; die Schwelle, ab der die eigenen Fristen Ihres Kunden laufen.

Unterstützungszeitraum. Die Zeit, in der ein Hersteller Schwachstellen eines Produkts nach dem Cyber Resilience Act behandelt; mindestens fünf Jahre (E4).

Zentrale Kontaktstelle. Der Kontakt des Herstellers für Schwachstellenmeldungen, nicht auf automatisierte Werkzeuge beschränkt (E4).

Koordinierte Offenlegung von Schwachstellen. Die Richtlinie, nach der ein Hersteller gemeldete Schwachstellen entgegennimmt und behebt, bevor sie veröffentlicht werden.

Anlagennummer. Die Nummer, die D4 jedem vorhandenen Nachweis gibt; D1 und D5 verweisen darauf.

Eingefrorene Fassung. Eine datierte Kopie des Dokumentensatzes im Konto; die Überprüfung erzeugt eine neue.

Lücke. In diesem Toolkit: ein Feld, das der Betrieb selbst füllt, mit einem Satz daneben, der sagt, was die Entscheidung bedeutet und wo das Handbuch sie erklärt.

8 Quellen

Alle Quellen wurden am 19. Oktober 2026 am Original gelesen, soweit der Eintrag nichts anderes sagt. EUR-Lex- und RIS-Texte wurden im Browser geöffnet und der Artikeltext von der Seite übernommen; PDF-Dokumente wurden geladen und seitenweise durchsucht; die Fragebogenkataloge und Versichererformulare wurden per Websuche und Abruf gesammelt und stichprobenweise geprüft. Kopien der PDFs liegen beim Projekt. Zitate aus englischen Quellen sind unsere Übersetzung.

Unionsrecht

1. Richtlinie (EU) 2022/2555 des Europäischen Parlaments und des Rates vom 14. Dezember 2022 (NIS-2-Richtlinie). Art. 2 Abs. 1 und 2, Art. 3, Art. 21 Abs. 1 bis 5, Art. 23 Abs. 1 und 4, Anhänge I und II; deutsch und englisch. eur-lex.europa.eu/legal-content/DE/TXT/HTML/?uri=CELEX:32022L2555 · abgerufen 19.10.2026.
2. Durchführungsverordnung (EU) 2024/2690 der Kommission vom 17. Oktober 2024 mit Durchführungsbestimmungen zur Richtlinie (EU) 2022/2555 im Hinblick auf die technischen und methodischen Anforderungen der Risikomanagementmaßnahmen im Bereich der Cybersicherheit, ABl. L, 2024/2690, 18.10.2024, in Kraft seit 7. November 2024. Art. 2, 3 Abs. 1, 16; Erwägungsgründe 3 und 5; Anhang Nr. 1 bis 13, insbesondere 1.1, 2.2, 2.3, 3.1, 3.2, 3.6, 4.1, 4.2, 5.1.4, 5.2, 6.1, 6.3, 6.6, 6.7, 6.8, 6.9, 6.10, 7, 8.1, 9, 10.1, 10.3, 11.2, 11.3, 11.5, 11.6, 11.7, 12.4, 12.5; deutsch und englisch. eur-lex.europa.eu/legal-content/DE/TXT/HTML/?uri=OJ:L_202402690; Kommissionstext C(2024) 7151 final · abgerufen 19.10.2026.
3. Verordnung (EU) 2022/2554 des Europäischen Parlaments und des Rates vom 14. Dezember 2022 über die digitale operationale Resilienz im Finanzsektor (DORA). Art. 28 Abs. 8, Art. 30 Abs. 1 bis 5; englisch. eur-lex.europa.eu, CELEX 32022R2554 · abgerufen 19.10.2026.
4. Verordnung (EU) 2016/679 (Datenschutz-Grundverordnung), konsolidierte Fassung vom 4. Mai 2016. Art. 28 Abs. 1 bis 3, Art. 30 Abs. 1 und 5, Art. 32 Abs. 1, Art. 33, Art. 34; deutsch und englisch. eur-lex.europa.eu, CELEX 02016R0679-20160504 · abgerufen 19.10.2026.
5. Verordnung (EU) 2024/2847 des Europäischen Parlaments und des Rates vom 23. Oktober 2024 über horizontale Cybersicherheitsanforderungen für Produkte mit digitalen Elementen (Cyber Resilience Act), ABl. L, 2024/2847, 20.11.2024. Art. 2 Abs. 1, 3 Nr. 1, 13 Abs. 1, 8, 17, 14 Abs. 1 und 2, 71; Erwägungsgründe 63 und 64; Anhang I Teil II; Anhang II; englisch. eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=OJ:L_202402847 · abgerufen 19.10.2026.
6. Empfehlung 2003/361/EG der Kommission vom 6. Mai 2003 betreffend die Definition der Kleinstunternehmen sowie der kleinen und mittleren Unternehmen, Anhang, Art. 2 · abgerufen 19.10.2026.

Österreich

7. Netz- und Informationssystemsicherheitsgesetz 2026 (NISG 2026), BGBl. I Nr. 94/2025 vom 23. Dezember 2025, Kernteile in Kraft seit 1. Oktober 2026. §§ 3a, 24, 25, 26, 29, 32, 33, 51. ris.bka.gv.at, PDF des Bundesgesetzblatts · abgerufen 19.10.2026.
8. Netz- und Informationssystemsicherheits-Verordnung 2026 (NISV 2026), Verordnung der Cybersicherheitsbehörde, BGBl. II Nr. 290/2026 vom 1. Oktober 2026. §§ 1, 2, 9 im Wortlaut; §§ 3 bis 5 als Zusammenfassung des Abrufs. ris.bka.gv.at · abgerufen 19.10.2026.
9. Bundesamt für Cybersicherheit, Seiten zu Registrierung und Pflichten · abgerufen 19.10.2026.
10. Wirtschaftskammern Österreichs, Cyber-Security-Hotline, Seitendatum 1. Juni 2026. wko.at/it-sicherheit/cyber-security-hotline · abgerufen 19.10.2026.
11. CERT.at, Startseite und Kontakt. cert.at · abgerufen 19.10.2026.
12. Bundeskriminalamt, Meldestellen (bundeskriminalamt.at/602) und CEO Fraud / Business E-Mail Compromise (bundeskriminalamt.at/212/eigentum/betrug/ceo_fraud.html), letzte Aktualisierung 29. Juni 2026 · abgerufen 19.10.2026.
13. polizei.gv.at, Notruf- und Notfallnummern in Österreich · abgerufen 19.10.2026.
14. Datenschutzbehörde, Meldung Data Breach. dsb.gv.at · abgerufen 19.10.2026.
15. onlinesicherheit.gv.at (Bundeskanzleramt und A-SIT), Erpressungstrojaner: Was tun bei Infektion?, letzte Aktualisierung 23. Juli 2022 · abgerufen 19.10.2026.
16. Wirtschaftskammer Oberösterreich, Achtung: Betrug mit geänderten Kontodaten in E-Mails und PDF-Rechnungen, 22. Juli 2025 · abgerufen 19.10.2026.
17. Cyber Trust Austria (CTS Cyber Trust Services GmbH, KSV1870, Kompetenzzentrum Sicheres Österreich), Cyber Risk Rating & Cyber Trust Label Schema Policy 2026, Version 6.0 vom 8. September 2025, 23 Seiten; cyber-trust.at, Labelübersicht, Fragenliste B, FAQ · abgerufen 19.10.2026.
18. Bundeskanzleramt und A-SIT, Österreichisches Informationssicherheitshandbuch, Version 4.4.0 vom 6. November 2023. sicherheitshandbuch.gv.at · abgerufen 19.10.2026.

Deutschland

19. Gesetz über das Bundesamt für Sicherheit in der Informationstechnik (BSI-Gesetz) in der Fassung des deutschen NIS-2-Umsetzungsgesetzes, in Kraft seit 6. Dezember 2025. §§ 28, 30, 32, 33. gesetze-im-internet.de · abgerufen 19.10.2026.
20. Bundesamt für Sicherheit in der Informationstechnik: NIS-2 für IT und TK; CyberRisikoCheck (bsi.bund.de/dok/crc); Pressemitteilung vom 6. Juni 2025; Die Lage der IT-Sicherheit in Deutschland, Abschnitt KMU; IT-Notfallkarte

(bsi.bund.de/dok/13003500, allianz-fuer-cybersicherheit.de); Pressemitteilungen zu Passwörtern vom 31. Januar 2025 und 30. Januar 2026; IT-Grundschutz-Kompendium, Edition 2023, ORP.2 und ORP.4 · abgerufen 19.10.2026.

21. BSI, Bundeskriminalamt, Charter of Trust, DIHK, eco, Initiative Wirtschaftsschutz, NIFIS, VOICE, Allianz für Cyber-Sicherheit, TOP 12 Maßnahmen bei Cyber-Angriffen, September 2019 · abgerufen 19.10.2026.
22. BVMW mit BSI, Die Anwendung des CyberRisiko-Checks auf Basis der DIN SPEC 27076, Leitfaden für IT-Dienstleistungsunternehmen, August 2023; DIN Media, DIN SPEC 27076:2023-05, Produktseite · abgerufen 19.10.2026. Die Spezifikation selbst wurde nicht gelesen.
23. Polizei, Zentrale Ansprechstellen Cybercrime (polizei.de); BfDI, Kontakt zu den Landesbehörden · abgerufen 19.10.2026.
24. VdS Schadenverhütung GmbH, VdS 10000 : 2025-01 (03), Informationssicherheitsmanagementsystem für kleine und mittlere Unternehmen, Auszug mit Inhaltsverzeichnis; VdS 5569 : 2018-10, Cyber-Security-Standards für den Mittelstand; vds.de · abgerufen 19.10.2026.

EU-Agenturen und Normungsstellen

25. ENISA, Cybersecurity guide for SMEs: 12 steps to securing your business, 28. Juni 2021 (auch deutsch: KMU-Leitfaden zur Cybersicherheit, 12 Schritte); Cybersecurity for SMEs: Challenges and Recommendations, Juni 2021 · abgerufen 19.10.2026.
26. ENISA, NIS2 Technical Implementation Guidance, Version 1.0, Juni 2025, 170 Seiten · abgerufen 19.10.2026. Beratend, nicht verbindlich.
27. NIST, Special Publication 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, Juli 2025, Abschnitte 3.1.1.1, 3.1.1.2, 3.2.2 · abgerufen 19.10.2026.
28. CISA, Implementing Phishing-Resistant MFA, Oktober 2022 · abgerufen 19.10.2026.
29. ISO/IEC 27001:2022, bibliografische Angaben bei committee.iso.org und im IEC Webstore; SC 27 Journal 2025, Heft 1 · abgerufen 19.10.2026. Die Norm selbst wurde nicht gelesen.
30. ENX Association, TISAX-Handbuch, Version 2.8; NIS2 fulfilment through TISAX, 24. April 2025; VDA, Seiten zur Informationssicherheit · abgerufen 19.10.2026.
31. Shared Assessments, SIG, und Which SIG Should I Use?, 2023 · abgerufen 19.10.2026.

Versicherer

32. Mannheimer Versicherung AG, Fragebogen Cyber-Risiken für Unternehmen ab 10 Mio. Euro Umsatz, HF_060 0424 · abgerufen 19.10.2026.
33. Markel Insurance SE, Fragebogen für Cyber-Versicherungen Pro Cyber v2 · abgerufen 19.10.2026.
34. Allianz Versicherungs-AG, Fragebogen für Unternehmen der Informationstechnologie, 9.25 · abgerufen 19.10.2026.
35. Beazley, Sicherheitsanforderungen für die Cyber Versicherung, ohne Datum, auf wko.at gehostet · abgerufen 19.10.2026.
36. Funk International Austria GmbH mit Beazley, Versicherungsantrag und Risikofragebogen Cyber-Versicherung, Juli 2022 · abgerufen 19.10.2026. Maklerformular.
37. Donau Versicherung AG, Allgemeine Bedingungen für die Cyberversicherung (Fassung 2025), 4. August 2025 · abgerufen 19.10.2026.
38. LG Kiel, Urteil vom 23. Mai 2024, 5 O 128/21; OLG Schleswig, Urteil vom 8. Januar 2025, 16 U 63/24; nur aus Sekundärquellen bekannt, nicht gelesen.